

MITRE ATT&CK: State of the Art and Way Forward

BADER AL-SADA, Division of Information and Computing Technology, College of Science and Engineering, Hamad Bin Khalifa University, Qatar Foundation, Qatar

ALIREZA SADIGHIAN, Division of Information and Computing Technology, College of Science and Engineering, Hamad Bin Khalifa University, Qatar Foundation, Qatar

GABRIELE OLIGERI, Division of Information and Computing Technology, College of Science and Engineering, Hamad Bin Khalifa University, Qatar Foundation, Qatar

MITRE ATT&CK is a comprehensive framework of adversary tactics, techniques, and procedures based on real-world observations. It has been used as a foundation for threat modeling in different sectors, such as government, academia, and industry. To the best of our knowledge, no previous work has been devoted to the comprehensive collection, study, and investigation of the current state of the art leveraging the MITRE ATT&CK framework. We select and inspect more than 50 major research contributions, while conducting a detailed analysis of their methodology and objectives in relation to the MITRE ATT&CK framework. We provide a categorization of the identified papers according to different criteria such as use cases, application scenarios, adopted methodologies, and the use of additional data. Finally, we discuss open issues and future research directions involving not only the MITRE ATT&CK framework but also the fields of threat analysis, threat modeling, and in general cyber-threat intelligence.

CCS Concepts: • **Security and privacy** → *Trust frameworks*;

Additional Key Words and Phrases: MITRE ATT&CK framework, cyber-threat intelligence, security risk analysis

ACM Reference Format:

BADER AL-SADA, Alireza Sadighian, and Gabriele Oligeri. 2024. MITRE ATT&CK: State of the Art and Way Forward. *ACM Comput. Surv.* 57, 1, Article 12 (October 2024), 37 pages. <https://doi.org/10.1145/3687300>

1 Introduction

Inter-connectivity and smart technologies are becoming more and more popular in our daily life. The paradigms of fog, edge and cloud computing enable the end-user to interact with an increasing number of remote services. The global trend of “get everything connected” is affecting the industry (Industry 4.0), cities (smart cities), houses (smart homes), and so on. Nevertheless, the high density of online services, sensors, and actuators is increasing the likelihood of cyber security attacks given the amount of known (and unknown, i.e., zero-day) vulnerabilities that are spread in all the online

B. AL-Sada and A. Sadighian contributed equally to this research.

Authors' Contact Information: BADER AL-SADA, Division of Information and Computing Technology, College of Science and Engineering, Hamad Bin Khalifa University, Qatar Foundation, Ad-Dawhah, Qatar; e-mail: balsada@hbku.edu.qa; Alireza Sadighian, Division of Information and Computing Technology, College of Science and Engineering, Hamad Bin Khalifa University, Qatar Foundation, Ad-Dawhah, Qatar; e-mail: asadighian@hbku.edu.qa; Gabriele Oligeri, Division of Information and Computing Technology, College of Science and Engineering, Hamad Bin Khalifa University, Qatar Foundation, Ad-Dawhah, Qatar; e-mail: gabriele.oligeri@gmail.com.

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than the author(s) must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from [permissions@acm.org](https://permissions.acm.org).

© 2024 Copyright held by the owner/author(s). Publication rights licensed to ACM.

ACM 0360-0300/2024/10-ART12

<https://doi.org/10.1145/3687300>

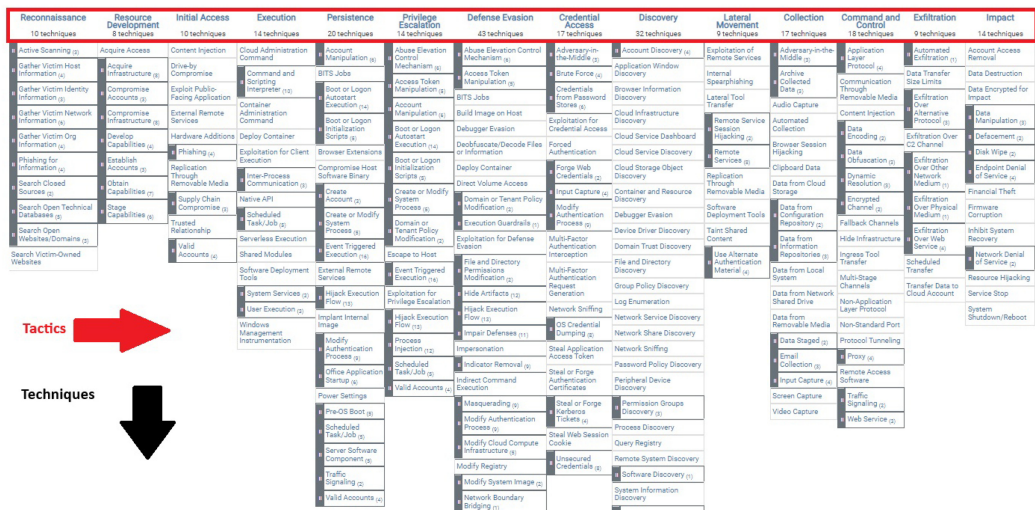
services [1]. The perimeter to be monitored, a.k.a., attack surface, by each organization is becoming too large to guarantee a zero-risk of penetration—eventually resulting on the acceptance of a minimum risk. Given the growing complexity **Information and Communication Technologies (ICT)** infrastructures, and the associated cyber security countermeasures, modern cyber security attacks are constituted by a sequence of steps that usually initiate from the weakest point in the attack surface (service security mis-configuration), and then, they move toward their final objective, e.g., data exfiltration, denial of service, subversion, and so on. In fact, contemporary cyber security attacks are characterized by a series of malicious activities carried out over an extended duration to ensure stealthiness during the lateral propagation of the attack [2]. The sequence of malicious operations, a.k.a., adversary behavior, is a fingerprint of the adversary itself. Indeed, the adversary aims at optimizing his workflow re-using the same tools, scripts and the overall methodology to gain access to a system. This pattern makes each adversary different and (at certain extent) identifiable. The MITRE ATT&CK framework [3] is a database of attacks, allowing a cross-match between adversarial objectives, behavior and attack sources. First, MITRE ATT&CK enables a detailed description of the threat landscape associated with a specific business—this being extremely important to allow the organization to prioritize the deployment of the assets’ controls. Moreover, for each attack in the database, MITRE ATT&CK provides the chain of malicious activities from the initial access to the final attack’s objective. This steps represent the adversarial behavior, which in turn, they can be considered as the fingerprint of the attack allowing the identification of the adversary. Finally, MITRE ATT&CK potentially allows the forecasting of the subsequent actions when the attack is detected as ongoing in the system—this allowing the localization and mitigation of the attack itself. This survey focuses on the MITRE ATT&CK knowledge-base applications and its enhancement and extension methods. To this aim, we identified a comprehensive list of papers that consider the MITRE ATT&CK framework in various ways. Next, we analyzed this list from different perspectives, such as adopted techniques, application scenario, type of their inputs, evaluation techniques, and so on, and present our findings and insights.

Contributions. The contributions of this article are manifold. First, we provide a comprehensive list of state of the art research papers related to the MITRE ATT&CK framework. We summarize each research paper describing its methodology, evaluation technique and future directions. Subsequently, we categorize the list of papers into four main categories: (i) Behavioral analytic, (ii) Red teaming, (iii) Defensive gap assessment, and, finally, (iv) **Cyber Threat Intelligence (CTI)** enrichment. We describe our findings and insights according to different categories, such as application scenarios, input types, adopted techniques, and input datasets. Finally, we present the limitations and the existing challenges in the current state of the art while providing some future directions.

Roadmap. The rest of this article is organized as follows. Section 2 is dedicated to the introduction of the background knowledge about the MITRE ATT&CK framework. Section 3 compares the MITRE ATT&CK with other frameworks, while Section 4 introduces the list of the selected paper and a preliminary break-down into use cases. Section 5 wraps up on the key-findings of our survey, while Section 6 highlights open issues and future research directions. Finally, Section 7 draws some conclusion remarks.

2 Background on MITRE ATT&CK Framework

MITRE ATT&CK stands for MITRE Adversarial Tactics, Techniques, and Common Knowledge (ATT&CK). It has been created in 2013 as a result of MITRE’s Fort Meade Experiment where a group of researchers emulated a scenario constituted by adversaries and defenders in an effort to improve the forensic analysis of an attack through the behavioral analysis of the adversary. The MITRE ATT&CK framework is a database of malicious activities from real world-observations.



The ATT&CK matrix also refers to *sub-techniques*, i.e., more specific techniques adopted by the adversary to achieve its goals. As an example, still related to *WannaCry* malware, we may consider T1573 (Encrypted Channel), which is characterized by two sub-techniques: T1573.001 (Symmetric Cryptography) and T1573.002 (Asymmetric Cryptography)—the later one adopted by *WannaCry*. Each technique (or sub-technique) can be implemented in different ways and a list of implementations are considered within the framework, i.e., the procedures associate with sub-technique T1573.002 are 55. The framework also links each considered malicious software, such as *WannaCry*-S0366, to the *groups* well known to have adopted it before, i.e., G0032-Lazarous Group. The ATT&CK framework also refers to well-known techniques to *detect* and *mitigate* each of the technique and sub-technique previously discussed. As a final example, M1031 (Network Intrusion Prevention) and M1020 (SSL/TLS Inspection) are suggested as mitigation to sub-technique T1573.002, while as for detection, DS0029 (Network Traffic) is suggested.

The MITRE attack framework involves three technology domains: *Enterprise*, *Mobile*, and **Industrial Control Systems (ICS)**. The three domains involve different tactics and

Table 1. WannaCry Tactics and Techniques

Tactics	Techniques
Execution	T1047. Windows Management Instrumentation
Persistence	T1543. Create or Modify System Process
Privilege escalation	T1543. Create or Modify System Process
Defense evasion	T1222. File and Directory Permissions Modification T1564. Hide Artifacts
Discovery	T1083. File and Directory Discovery T1120. Peripheral Device Discovery T1018. Remote System Discovery T1016. System Network Configuration Discovery
Lateral movement	T0866. Exploitation of Remote Services T1570. Lateral Tool Transfer T1563. Remote Service Session Hijacking
Command and Control	T1573. Encrypted Channel T1090. Proxy
Impact	T1486. Data Encrypted for Impact T1490. Inhibit System Recovery T1489. Service Stop

Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
Command and Scripting Interpreter	Account Manipulation	Access Elevation Control Mechanism	Access Elevation Control Mechanism	Adversary in the Middle	Account Discovery	Adversary in the Middle	Adversary in the Middle	Authentication Layer Protocol	Automated Exfiltration	Account Access Removal
Control Panel	BTFS Jails	Access Token Manipulation	Access Token Manipulation	Brute Force	Adversary in the Middle	Internal Spoofing	Adversary in the Middle	Communication Through Removable Media	Data Transfer Size Limits	Data Destruction
Default Container	Boot or Login Auditing Execution	Boot or Login Auditing Execution	BTFS Jails	Credentials From Password Stores	Browser	Local Tool Transfer	Audio Capture	Data Encryption	Exfiltration Over Alternative Protocol	Data
Exfiltration To Cloud Execution	Browser Extensions	Boot or Login Auditing Execution	Build Image on Host	Exfiltration For Credential Access	Cloud Infrastructure Discovery	Remote Service Session Hijacking	Automated Collection	Data Obfuscation	Exfiltration Over Cloud Channel	Data Manipulation
File Processes Communication	Browser Extensions	Control of Modify System Process	Debugger Support	Forward Authentication	Cloud Service Dashboard	Remote Services	Browser Session Hijacking	Dynamic Resolution	Exfiltration Over Other Network Medium	Defacement
Native API	Compromise Client Software Binary	Control of Modify System Process	Deobfuscate/Obfuscate File or Information	Forge Web Credentials	Cloud Object Discovery	Authentication Through Removable Media	Options Data	Encrypted Channel	Exfiltration Over Physical Medium	Disk Wipe
Scheduled Task/Job	Create Account	Control of Modify System Process	Device Control	Input Capture	Cloud Storage Object Discovery	Software Development Tools	Data from Cloud Storage Object	Fallback Channels	Exfiltration Over Web Service	Endpoint Control of Service
Shared Modules	Control of Modify System Process	Event Triggered Execution	Direct Volume Access	Modify Authentication Process	Container and Resource Discovery	System Shared Content	Data from Configuration Repository	Ingress Tool Transfer	Scheduled Transfer	Privilege Corruption
Software Deployment Tools	Event Triggered Execution	Event Triggered Execution	Exfiltration for Privilege Escalation	Network Sniffing	Domain Trust Discovery	Like Alternate Authentication Material	Data from Information Repositories	Multi-Stage Channels	Transfer Data to Cloud Account	Initial System Recovery
System Services	Event Triggered Execution	Event Triggered Execution	Exfiltration for Privilege Escalation	Network Sniffing	Domain Trust Discovery	Like Alternate Authentication Material	Data from Local System	Non-Application Layer Protocol	Transfer Data to Cloud Account	Network Control of Service
User Execution	Event Triggered Execution	Event Triggered Execution	Exfiltration for Privilege Escalation	Network Sniffing	Domain Trust Discovery	Like Alternate Authentication Material	Data from Network Shared Drive	Non-Standard Port	Transfer Data to Cloud Account	Resource Hijacking
Windows Management Instrumentation	Event Triggered Execution	Event Triggered Execution	Exfiltration for Privilege Escalation	Network Sniffing	Domain Trust Discovery	Like Alternate Authentication Material	Data from Removable Media	Non-Standard Port	Transfer Data to Cloud Account	Service Stop
Modify Authentication Process	Event Triggered Execution	Event Triggered Execution	Exfiltration for Privilege Escalation	Network Sniffing	Domain Trust Discovery	Like Alternate Authentication Material	Data from Local System	Non-Application Layer Protocol	Transfer Data to Cloud Account	System Shutdown/Reboot
Office Application Startup	Event Triggered Execution	Event Triggered Execution	Exfiltration for Privilege Escalation	Network Sniffing	Domain Trust Discovery	Like Alternate Authentication Material	Data from Local System	Non-Application Layer Protocol	Transfer Data to Cloud Account	System Shutdown/Reboot
Pre-OS Boot	Event Triggered Execution	Event Triggered Execution	Exfiltration for Privilege Escalation	Network Sniffing	Domain Trust Discovery	Like Alternate Authentication Material	Data from Local System	Non-Application Layer Protocol	Transfer Data to Cloud Account	System Shutdown/Reboot
Scheduled Task/Job	Event Triggered Execution	Event Triggered Execution	Exfiltration for Privilege Escalation	Network Sniffing	Domain Trust Discovery	Like Alternate Authentication Material	Data from Local System	Non-Application Layer Protocol	Transfer Data to Cloud Account	System Shutdown/Reboot
Server Software Component	Event Triggered Execution	Event Triggered Execution	Exfiltration for Privilege Escalation	Network Sniffing	Domain Trust Discovery	Like Alternate Authentication Material	Data from Local System	Non-Application Layer Protocol	Transfer Data to Cloud Account	System Shutdown/Reboot
Traffic Signaling	Event Triggered Execution	Event Triggered Execution	Exfiltration for Privilege Escalation	Network Sniffing	Domain Trust Discovery	Like Alternate Authentication Material	Data from Local System	Non-Application Layer Protocol	Transfer Data to Cloud Account	System Shutdown/Reboot
Valid Accounts	Event Triggered Execution	Event Triggered Execution	Exfiltration for Privilege Escalation	Network Sniffing	Domain Trust Discovery	Like Alternate Authentication Material	Data from Local System	Non-Application Layer Protocol	Transfer Data to Cloud Account	System Shutdown/Reboot

Fig. 2. WannaCry profile behavior techniques.

techniques—although there are some minor overlaps. Indeed, the three domains are very different each others, thus involving different adversarial behavior. The attack surfaces are different as well as the adversary objectives, thus requiring ad hoc tactics, techniques, and procedures.

Enterprise. This domain involves 191 techniques and 385 sub-techniques including several platform such as Windows, Linux, macOS, and so on. This is the richest domain due to its legacy involving observations of attacks from a technology domain that is physiologically broader than the others. Indeed, the enterprise domain involves the platform Windows, macOS, Linux, Cloud, Network and Containers, while being the only one to include specific techniques (within two tactics) for the analysis of the preparatory adversarial activities (PRE-ATT&CK). Indeed, worth-noting entry points in the ATT&CK matrix are Search Open Websites/Domains and Search

Victim-Owned Websites (Reconnaissance)—typical behavior for social engineering, while typical adversary objectives are Data Destruction, Disk Wipe and Service Stop (Impact)—techniques that commonly implemented by adversaries in enterprise scenarios.

Mobile. The mobile domain takes into account 66 techniques and 41 sub-techniques. The mobile domain has the main objective to perform a behavioral analysis of attacks involving smart-phones and related devices. The increasing adoption of smart-phones for accessing and sharing personal and corporate data, e.g., Bring Your Own Device model, significantly expand the attack surface while increasing the number of the associated threats. Indeed, countless attacks have been proposed against smart-phones, and those attacks are becoming more and more targeted to the user's organization, given the entry points offered by the smart-phones vulnerabilities. The mobile ATT&CK matrix addresses this scenario considering specific attack behavior with typical entry points of smart-phones, e.g., Lockscreen Bypass and Supply Chain Compromise (Initial Access), while aiming at targets that can involve more than the user's data, e.g., Input Injection and Data Encrypted for Impact (Impact).

Industrial Control Systems. The ICS domain is represented by 78 techniques with no sub-techniques. Modern cyber-physical systems are experience the convergence of **Information Technology (IT)** and **Operational Technology (OT)** throughout the new models of fog and edge computing. Indeed, the OT infrastructure is now connected to the network with processing capabilities—being able to implement AI techniques in some cases, thus enabling the full integration of data-centric computing (IT) with monitoring and sensing from the physical world (OT). While the increasing integration of OT and IT enhance the effectiveness and efficacy of the industrial processes, it represents an unprecedented opportunity for adversaries than can now jump from one world to the other, thus increasing their chances to affect the physical environment by initiating attacks in the cyber-space. The ICS ATT&CK matrix captures this IT-OT relation by considering attack behavior that initiate from the IT world, e.g., Spearfishing attachment, Wireless Compromise, Internet Accessible Device (Initial access), ending up with a physical impact in the OT world, e.g., Damage to Property, Denial of Control, and Loss of Safety (Impact).

3 Comparison with Other Frameworks

Many known frameworks/models support threat analysis, threat modeling, threat profiling, threat assessment and risk analysis activities. Considering that our main focus in this survey is threat analysis & modeling, we selected the following frameworks that follow similar objectives as MITRE ATT&CK: (i) Lockheed Martin's **Cyber Kill Chain (CKC)**, (ii) Microsoft **STRIDE framework (STRIDE)**, (iii) **Unified Kill Chain (UKC)**, (iv) the **Diamond model (DM)**, (v) **Damage, Reproducibility, Exploitability, Affected Users, Discoverability (DREAD)**, (vi) **Process for Attack Simulation and Threat Analysis (PASTA)**, (vii) NIST SP 800-154: Guide to Data-Centric System Threat Modeling. In the following, we briefly describe each one.

- **Lockheed Martin's Cyber Kill Chain [4]:** This framework involves 7 stages, i.e., Reconnaissance, Weaponization, Delivery, Exploitation, Installation, Command and Control, and Actions on Objectives. The idea behind the framework is rooted on the fact that all the cyber security attacks can be either represented or mapped in terms of a sequence of temporal activities belonging to the aforementioned stages. It is strictly important that the temporal sequence is respected: the success of the attack is tied to the temporal sequence of the adversary's actions. Indeed, this makes the attack (or the perception of it) much weaker: any action that breaks the chain (sequence of malicious activities) prevents the adversary to achieve its goal.
- **Microsoft STRIDE:** This framework has been proposed and developed by Praerit Garg and Loren Kohnfelder at Microsoft [5]. The model leverages six threat categories: Spoofing,

Tampering with data, Repudiation, Information disclosure, Denial of service and Elevation of privilege. The main idea is to identify a specific service from the corporate architecture, and then, adopt the six categories to identify all the possible threats, and finally, iterating the methodology for each service in the organization. This framework allows to identify vulnerabilities, and the associated threats, while been driven by the STRIDE categories.

- **Unified Kill Chain [6]**: This framework has been proposed by Paul Pols in 2017 as the result of his Master Thesis. UKC both extends and improves the CKC by considering threats that go beyond malware and the corporate perimeter. Nevertheless, UKC is still based on a (more extended) sequence of adversary actions being based on the concept of *kill chain*.
- **Diamond model [7]**: it is mainly considered in the field of intrusion analysis. DM involves 4 entities, i.e., the adversary, the capability, the infrastructure, and the victim. The analysis of the intrusion is performed by considering a description of the “adversary”, its “capabilities”, how it interacts with the target “infrastructure” to achieve its objectives against the “victim.”
- **Damage, Reproducibility, Exploitability, Affected Users, Discoverability [8]**: it is a threat model framework developed by Microsoft in 2003 that serves to quantify an overall threat score based on the five key elements, and it is customizable for an organization to easily adopt it. The outcome of the models enables structured threat rating and supports prioritization of identified threats while also allowing easy comparison values between each threat type.
- **Process for Attack Simulation and Threat Analysis [9]**: The PASTA model consists of step steps: (i) Defining the objectives, (ii) Define the Technical scope, (iii) Decompose the application, (iv) Analyzing the threats, (v) Vulnerability analysis, (vi) Attack analysis, and (vii) Risk and Impact analysis. PASTA threat framework takes into consideration business context, a collaboration between different stakeholders, evidence-based and threat intelligence while also focusing on the probability of certain attacks occurring.
- **NIST SP 800-154 Guide to Data-Centric System Threat Modeling [10]**: NIST 800-154 is a generic cyber threat modeling that considers both offensive and defensive perspectives toward protecting both logical and physical assets. The published model highly focused on data as a center of protection and how to integrate it into risk management in general. It provides a framework for identifying and managing security risks within systems by focusing on the data that those systems process. This approach emphasizes the importance of understanding data flows, the locations where data is stored and processed, and the potential threats to that data. By following the steps outlined in the guide, organizations can better understand and mitigate the risks associated with their data, leading to a more robust security posture.

The objectives and the scopes of the above frameworks/models are different. For example, STRIDE might be used to identify a threat associated with one or more services in the organization, CKC might support the modeling of the attack associated with the threat while highlighting potential mitigation. The Diamond model is for intrusion analysis to build a historical and wide view of cyber attacks with technical information. The DREAD model is a tool for assessing and prioritizing security threats by considering their potential impact, ease of exploitation, and scope of affected users. PASTA enables the identification of security vulnerabilities, the simulation of potential attacks, and the assessment of the impact of those attacks on a system or organization. NIST SP 800-154 provides a comprehensive guide to implementing data-centric threat modeling, emphasizing the protection of critical data assets within an organization’s systems.

Figure 3 shows a diagram (center of the figure) associated with a generic cyber security attack involving several steps (from Step 1 to Step 6) affecting the ICT infrastructure before reaching the

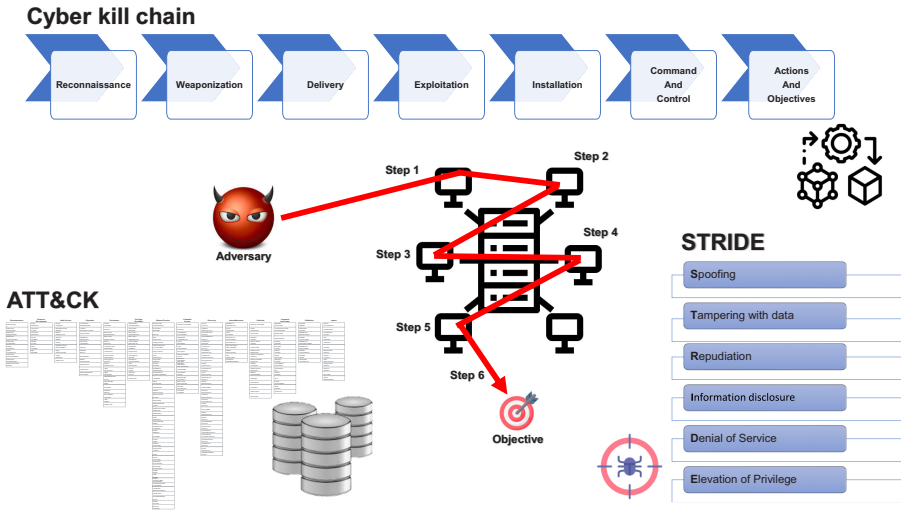


Fig. 3. ATT&CK, Cyber Kill Chain and STRIDE: Comparison and application scenarios.

final adversary objective. The STRIDE framework can support the analysis and early identification of vulnerabilities associated with the entry point (Step 1), each of the services exploited by the adversary to move throughout the ICT infrastructure (Step 2 to 5), and finally, the vulnerability associated with the target objective (Step 6). Conversely, CKC can be effectively adopted to create a model of the consecutive and causal events that allows the adversary to reach its objective (Step 6) from early stages (Step 1)—it is worth highlighting that a proper modeling can help the security risk assessment team to break the attack at each step by deploying the correct countermeasure thus preventing the adversary to move forward and reaching its objective.

4 In-depth Analysis and Use Cases Mapping

In this section, we introduce the list of the papers taken into account in this survey. For this purpose, we follow one of the widely used systematic review strategies, called Preferred Reporting Items for Systematic reviews and Meta-Analyses Statement [11], that leads researchers toward high-quality and comprehensive literature reviews. In the planning phase, we clearly define our research question (“why and how MITRE ATT&CK has been used in the literature?”) and the main objective (“describing the importance and potentials of MITRE ATT&CK for cybersecurity research projects”) of this review. In the searching phase, we define our predetermined search terms (MITRE and ATT&CK) and Boolean operators (AND) and conduct comprehensive searches across popular and prevalent research databases (Google Scholar, ResearchGate, and arXiv). In the screening and eligibility phase, we analyze titles and abstracts of retrieved articles against our pre-defined inclusion and exclusion criteria, and transfer the acceptable articles along with their full text into our main article repository. In this literature review, we only consider the contributions where the MITRE ATT&CK framework is a strict requirement for achieving the objectives of the paper, while we discarded all the other ones. Tables 2 and 3 shows the list of the considered papers, where we report the title of the paper, the year of the publication, the authors’ country, and finally, the number of citations collected up to the writing of this survey. In the data extraction phase, we extract data, characteristics, and various types of insights from our listed articles. Finally, we summarize and describe our findings and key insights to provide future guidelines and directions for other researchers.

Table 2. Our Reference List of Papers (1/2)

Reference	Title	Year	Country	N. Citations
[12]	HOLMES: Real-time APT Detection through Correlation of Suspicious Information Flows	2019	US	417
[13]	Cyber Threat Intelligence Model: An Evaluation of Taxonomies, Sharing Standards, and Ontologies within Cyber Threat Intelligence	2017	NO	331
[14]	Tactical Provenance Analysis for Endpoint Detection and Response Systems	2020	US	198
[15]	TTPDrill: Automatic and Accurate Extraction of Threat Actions from Unstructured Text of CTI Sources	2017	US	195
[16]	Cyber security threat modeling based on the MITRE Enterprise ATT&CK Matrix	2022	SE, FR	138
[17]	Learning the associations of MITRE ATT&CK adversarial techniques	2020	US	116
[18]	Assessing MITRE ATT&CK Risk Using a Cyber-Security Culture Framework	2021	GR	91
[19]	A review of threat modelling approaches for APT-style attacks	2021	AU	78
[20]	Cyber threat dictionary using MITRE ATT&CK matrix and NIST cybersecurity framework mapping	2020	US	74
[21]	A machine learning framework for investigating data breaches based on semantic analysis of adversary's attack patterns in threat intelligence repositories	2019	US,PK	60
[22]	Automated Retrieval of ATT&CK Tactics and Techniques for Cyber Threat Reports	2020	NL, DE	60
[23]	Modeling attack, defense and threat trees and the cyber kill chain, ATT&CK and STRIDE frameworks as blackboard architecture networks	2020	US	59
[24]	Sok: Att&ck techniques and trends in windows malware	2019	NL	46
[25]	Data-Driven Decision Support for Optimizing Cyber Forensic Investigations	2021	US, UK	45
[26]	Optimal Machine Learning Algorithms for Cyber Threat Detection	2018	SA	44
[27]	Integrating Cyber-D&D into Adversary Modeling for Active Cyber Defense	2016	US	42
[28]	Linking CVE's to MITRE ATT&CK Techniques	2021	IE, FR	42
[29]	Analysis of automated adversary emulation techniques	2017	US	37
[30]	Characterizing Attacker Behavior in a Cybersecurity Penetration Testing Competition	2019	US	35
[31]	MITRE ATT&CK -driven Cyber Risk Assessment	2022	UK, GR	34
[32]	Probabilistic Attack Sequence Generation and Execution Based on MITRE ATT&CK for ICS Datasets	2021	KR	32
[33]	Towards a Definition of Cyberspace Tactics, Techniques and Procedures	2017	US	31
[34]	Linking Common Vulnerabilities and Exposures to the MITRE ATT&CK Framework: A Self-Distillation Approach	2021	US	31
[35]	Attack Hypothesis Generation	2019	IL	30
[36]	Automatically Attributing Mobile Threat Actors by Vectorized ATT&CK Matrix and Paired Indicator	2021	KR	29
[37]	From TTP to IoC: Advanced Persistent Graphs for Threat Hunting	2021	FR	28
[38]	A Threat Hunting Framework for Industrial Control Systems	2021	AU	28
[39]	SoK: A survey of open source threat emulators	2020	IL	27
[40]	On the Use of Cyber Threat Intelligence (CTI) in Support of Developing the Commander's Understanding of the Adversary	2019	NATO	26
[41]	TIM: threat context-enhanced TTP intelligence mining on unstructured threat data	2022	CH	26
[42]	Learning APT Chains from Cyber Threat Intelligence	2019	US	25
[43]	powerLang: a probabilistic attack simulation language for the power domain	2020	SW	24
[44]	Expansion of ICS Testbed for Security Validation based on MITRE ATT&CK Techniques	2020	KR	21
[45]	Open Source Intelligence for Malicious Behavior Discovery and Interpretation	2021	TW	21
[46]	Real Time early Multi Stage Attack Detection	2021	IN	19
[47]	Cyberattack Models for Ship Equipment Based on the MITRE ATT&CK Framework	2022	KR	19
[48]	Artificial Intelligence empowered Cyber Threat Detection and Protection for Power Utilities	2019	US	17
[49]	Identifying ATT&CK Tactics in Android Malware Control Flow Graph Through Graph Representation Learning and Interpretability	2021	US	17
[50]	Game-Theoretic decision support for cyber forensic investigations	2021	UK	17
[51]	Services for zero trust architectures-a research roadmap	2021	US	14
[52]	MITRE ICS Attack Simulation and Detection on EtherCAT Based Drinking Water System	2021	TR	14
[51]	Services for zero trust architectures-a research roadmap	2021	US	14
[53]	Automatic Mapping of Vulnerability Information to Adversary Techniques	2020	JP	14
[54]	Security Assessment Rating Framework for Enterprises using MITRE ATT&CK Matrix	2021	IN	14
[55]	Threat intelligence ATT&CK extraction based on the attention transformer hierarchical recurrent neural network	2022	CH	14
[56]	Introducing uwf-zeekdata22: A comprehensive network traffic dataset based on the MITRE ATT&CK framework	2023	US	13
[57]	Automating Cyber Threat Hunting Using NLP, Automated Query Generation, and Genetic Perturbation	2021	US	13
[58]	Towards Dynamic Threat Modelling in 5G Core Networks Based on MITRE ATT&CK	2021	UK	13
[59]	Evolution of IoT Linux Malware: A MITRE ATT&CK TTP Based Approach	2021	IT	13

Table 3. Our Reference List of Papers (2/2)

Reference	Title	Year	Country	N. Citations
[60]	Application of Advanced Persistent Threat Actors' Techniques for Evaluating Defensive Countermeasures	2020	RU	10
[61]	GroupTracer: automatic attacker TTP profile extraction and group cluster in Internet of things	2020	CH	9
[62]	Attack Specification Language: Domain Specific Language for Dynamic Training in Cyber Range	2021	PK	9
[63]	Fingerprint for Mobile-Sensor APT Detection Framework (FORMAP) Based on Tactics Techniques and Procedures (TTP) and MITRE	2022	MY	9
[64]	DMAPT: Study of Data Mining and Machine Learning Techniques in Advanced Persistent Threat Attribution and Detection	2021	IN	9
[65]	Price TAG: Towards Semi-Automatically Discovery Tactics, Techniques and Procedures of E-Commerce Cyber Threat Intelligence	2021	CN	9
[66]	MITRE ATT&CK Based Evaluation on In-Network Deception Technology for Modernized Electrical Substation Systems	2022	SG	8
[67]	A Model and Method of Information System Security Risk Assessment based on MITRE ATT&CK	2021	CH	7
[68]	Visualizing Interesting Patterns in Cyber Threat Intelligence Using Machine Learning Techniques	2022	PK, SK	6
[69]	Clustering using a similarity measure approach based on semantic analysis of adversary behaviors	2020	CN	4
[70]	Enhancing the STIX Representation of MITRE ATT&CK for Group Filtering and Technique Prioritization	2022	NO	3
[71]	Exploiting ttp co-occurrence via glove-based embedding with mitre ATT&CK framework	2023	KR	2
[72]	Security assessment based on attack graphs using NVD and MITRE ATT&CK database for heterogeneous infrastructures	2024	RU	0

We identified different perspectives in the considered manuscripts. MITRE ATT&CK has been utilized mostly in two different ways: (i) as a matrix or structured framework to map tactics and techniques [11, 37], or (ii) as a threat profile database [10, 45]. On the contrary, Reference [13] has used MITRE ATT&CK to build an automated adversary simulation, while Reference [5] has used MITRE ATT&CK to propose a threat detection mechanism, while Reference [7] has used MITRE ATT&CK using **Natural Language Processing (NLP)** techniques to extract information and insights from unstructured cyber security reports.

Inspired by the seminal white paper [3], we initiate our analysis by categorizing the works as a function of the use cases proposed in Reference [3]: (i) Behavioral analytic, (ii) Red teaming, (iii) Defensive gap assessment, and (iv) CTI enrichment.

Two use-case categorizations, “**Security Operation Centers (SOC)** Maturity Assessment” and “Adversary Emulation” were included under “Defensive Gap Assessment” and “Red Teaming,” respectively, as they were employed by a very low number of articles and due to their higher relevancy. It is worth noting that the main challenges we encountered during categorization were as follows: (i) some of the articles were matched with multiple categories (matching overlap) and (ii) some other papers use different keywords for the same or similar concepts (e.g., threat actor and adversary interchangeable). In general, the categories identify the behavior of adversaries in various types of existing and emerging attacks, helping to improve MITRE ATT&CK knowledge base and framework. This categorization can be used by practitioners, researchers, and defenders

Table 4. Use-case Categories

Use Cases	Papers
Behavioral analytic	[12, 14, 17, 21, 23, 24, 26, 30, 38, 45, 48, 52, 57, 61], [31, 46, 49, 50, 56, 59, 63, 64, 69, 72]
CTI enrichment	[13, 15, 18, 20, 22, 25, 27, 28, 33, 35, 36, 40, 42, 44], [34, 41, 53, 55, 65, 68, 70, 71]
Adversary Emulation / Red teaming	[16, 19, 29, 32, 37, 39, 43, 58, 62]
Defensive Gap Assessment	[47, 51, 54, 60, 67]

to better identify and describe the suitable adversary models, evaluation techniques, and the associated references for their analysis.

Table 4 summarizes this categorization, while in the following, we map the papers to each identified category.

Recently, another contribution [73] proposed a novel taxonomy categorizing ATT&CK-oriented applications, use cases, and research approaches. Their work aim at showing the utility of ATT&CK and identify research gaps. Finally, the paper emphasizes the need for more practical implementation and evaluation of ATT&CK in both academia and industry. Our current contribution and [73] complement each other by providing a broad overview and a detailed classification of ATT&CK applications and methodologies. In particular, the two papers provide comprehensive insights into the use of the MITRE ATT&CK framework, but from different points of view. Our contribution offers a detailed survey and categorization of existing research, highlighting applications in behavioral analytics, red teaming, defensive gap assessment, and CTI enrichment, and providing insights on methodologies, data sources, and future research directions. In contrast, the paper from [73] introduces a novel taxonomy to systematically classify ATT&CK-based applications and research approaches, emphasizing practical implementations and identifying gaps for future study. While our contribution focuses on categorizing research and analyzing methodologies, [73] aims to provide a structured overview of ATT&CK's usefulness across various domains and its integration with other security frameworks. Together, they complement each other, offering both a broad survey and a detailed classification of ATT&CK applications and research methodologies.

4.1 Behavioral Analytic

In this section, we consider all the papers addressing the analytical description of the adversary behavior throughout different methodologies, input and metrics. Indeed, the behavior of the adversary is a key component for both forensic and forecasting purposes, while the ATT&CK framework represents a rich source of information to this goal. In the remainder of this section, we consider all the papers dealing with the analysis of the adversarial behavior by either considering the data from the ATT&CK matrix or from real-world dataset that are mapped to the tactics, techniques and procedures in the ATT&CK matrix.

4.1.1 Learning the Associations of MITRE ATT&CK Adversarial Techniques, 2020 [17]. Authors propose a machine learning-based approach employing hierarchical clustering in particular to extract the associations of attack techniques from APT and software attack data from the MITRE ATT&CK framework. This work identifies three key challenges: (i) how important is the establishing an appropriate distance metric for clustering technique associations while maintaining interpretability, (ii) handling multi-dimensional relationships demonstrated by attack techniques; and finally, and (iii) verifying the consistency and importance of the learned hierarchical clustering and techniques associations. For this purpose, authors explore various partitioned clustering

methods, e.g., Partition Around Medoids, k -means, and Fuzzy clustering, and hierarchical methods for clustering attack techniques that take place together in the TTP chain. Nevertheless, given the complexity of the adversarial behavior and the associated techniques constituting the attack, most of the classic clustering algorithms fails to capture usable associations; therefore, based on their results, they choose hierarchical clustering to represent attack patterns. Accordingly, from APT attacks dataset, they are able to infer 37 fine-grain technique associations and from software attack dataset, they are able to infer 61 technique associations. Mutual information has been considered as main criterion for evaluation, and their results show acceptable predictability for APT attacks (78% of the fine-grain and 75% coarse-grain technique associations).

4.1.2 Characterizing Attacker Behavior in a Cyber Security Penetration Testing Competition, 2019 [30]. This research proposes an analytical approach to characterize attackers behavior based on a dataset of events collected from the 2018 National Collegiate Penetration Testing Competition. The main objective is to familiarize developers and administrators with attackers mindsets using tactics and techniques from the MITRE ATT&CK framework. For this purpose, authors analyze a inter-modal dataset including over 500 million events from six teams of attackers. The main phases of the proposed approach is evidence gathering by analyzing exploited vulnerabilities and behavior characterization by mapping captured events to the tactics and techniques of the ATT&CK framework. The evaluation is performed by applying the identified methodology to the events associated with the different teams.

4.1.3 Modeling Attack, Defense and Threat Trees and the Cyber Kill Chain, ATT&CK, and STRIDE Frameworks as Blackboard Architecture Networks, 2020 [23]. Authors propose the **Blackboard Architecture Cyber Command Entity Attack Route (BACCER)** that is a generalized approach to model and analyze framework/paradigm-based attacks. While best practices involve the deployment of a single exploit for a single identified target, authors propose to combine rules and facts that demonstrate attack types and corresponding decision making logic with actions: BACCER uses Blackboard Architecture networks [74] to model and analyze attack paradigms. BACCER's efficiency has been verified by modeling and implementing samples of attack and defense trees. Finally, authors also discussed its efficacy to model other types of frameworks, such as the MITRE ATT&CK framework.

4.1.4 Tactical Provenance Analysis for Endpoint Detection and Response Systems, 2020 [14]. This research introduces a concept, called Tactical Provenance, that represents casual dependencies between threat alerts generated by **Endpoint Detection and Response (EDR)** solutions. They encode casual dependencies into **Tactical Provenance Graphs (TPG)** that are more compressed compared to classical whole-system provenance graphs as of their abstract nature and better visualization capabilities. This helps the security analysts to optimize the inspection process. As the next phase of their research, the authors propose a threat scoring algorithm based on TPGs to assign appropriate scores and rank threat alerts. MITRE ATT&CK framework is used as a knowledge base for their threat analyzing and processing tasks. The proposed approach is evaluated using the Symantec EDR tool in an enterprise environment. They claim that the achieved results show 87% overhead reduction in system logs storage. Moreover, the proposed approach enhances the threat detection precision of the Symantec EDR.

4.1.5 Sok: Att&ck Techniques and Trends in Windows Malware, 2019 [24]. This research has conducted an automated analysis and investigation of a sample dataset of 951 Windows malware families mapped and plotted on the MITRE ATT&CK framework. The authors claim that this research work is the first to use the MITRE ATT&CK framework to present the results of analyzing a large samples of malware. The malware samples have been collected from Malpedia that is a malware

database developed and maintained by Fraunhofer FKIE.¹ For malware analysis, the authors use Joe Sandbox Cloud,² which is a public environment automating dynamic inspection for static and network analysis. Their results show an improvement in the implementation of file-less execution vectors using Windows Management Instrumentation and PowerShell, discovery of security software and DLL side-loading for defense evasion. These results indicate how malware developers are empowering their tactics to bypass classic and traditional defense strategies.

4.1.6 A Threat Hunting Framework for Industrial Control Systems, 2021 [38]. An ICS Threat Hunting Framework for early ICS cyber threat detection is proposed in Reference [38]. The proposed framework has three main phases: (i) an initial phase devoted to the detection of any event or external resource triggering the hunting stage, e.g., notifications from third parties and data received from security analysts; (ii) a threat hunting phase that combines and aggregates two source of data, MITRE ATT&CK framework and Diamond intrusion analysis model, to define and build a hunting hypothesis for predicting the future actions of the adversary; and finally, (iii) a CTI phase to generate **Indicators of Compromises (IoCs)**, such as TTPs, IPs, and so on, to aid organizations learning existing threats. In the proposed framework, CTI is extracted from the actions of identified adversaries. For the evaluation of the proposed approach, they use three scenarios: (i) Black Energy 3 malware, (ii) PLC-Blaster malware, and, finally, and (iii) SWaT dataset. Based on the obtained results, the authors claim that enterprises can leverage the proposed framework to design and develop customized threat hunting solutions for their own ICS networks.

4.1.7 MITRE ICS Attack Simulation and Detection on EtherCAT-based Drinking Water System, 2021 [52]. Authors propose a machine learning-based detection approach along with a host-based intrusion detection for protecting EtherCAT-based drinking water system. In particular, authors propose a **Support Vector Machines- (SVM)** based detection algorithm for detecting attacks on field devices. Moreover, they use Wazuh HIDS³ for detecting attacks within the SCADA system control center. Attack vectors have been designed based on the techniques of the MITRE ICS ATT&CK matrix during their design and development. Finally, they adopted Elasticsearch, Logstash and Kibana (ELK Stack) to visualize the proposed detection system.

4.1.8 Clustering Using a Similarity Measure Approach Based on Semantic Analysis of Adversary Behaviors, 2020 [69]. This work describes a three-layer approach to analyze the statistical features of APT groups. Those three layers are Goal, Behavior, and Capability. Authors mainly concentrate on the statistical features of APT groups, and utilize this model to analyze optimized methods of using threat intelligence information. Next, they present a similarity measuring method to capture similarity degree considering different semantic relationships between groups. Finally, they considered the Girvan-Newman clustering algorithm [75] to find community groups. In their experiments, they build a knowledge network for the behavior analysis leveraging the MITRE ATT&CK data, and finally, they considered the similarity among the groups by building a knowledge network from the collected data.

4.1.9 MITRE ATT&CK-driven Cyber Risk Assessment, 2022 [31]. Authors propose a hybrid cyber risk assessment methodology based on the (i) vulnerability-oriented approach, (ii) asset/impact-oriented approach, and (iii) threat-oriented approach. This work combines the ATT&CK repository with attack graphs to calculate attacks' occurrence probability and their potential success rate. For this purpose, first, it identifies business-critical objectives and corresponding threats. Then,

¹<https://malpedia.caad.fkie.fraunhofer.de/>

²<https://www.joesandbox.com/>

³<https://documentation.wazuh.com/3.13/user-manual/capabilities/anomalies-detection/how-it-works.html>

it identifies special threat and environmental parameters to analyze the threat and its potential impacts. To summarize, the proposed methodology has three main steps: (i) organization modeling, (ii) threat modeling, and, finally, (iii) impact assessment. The evaluation is supported by a case study of a health center located in the United Kingdom to conduct a series of risk analysis tasks against two adversary groups, i.e., Lazarus and menuPass.

4.1.10 HOLMES: Real-time APT Detection Through Correlation of Suspicious Information Flows, 2019 [12]. Authors propose an APT detection system, namely HOLMES, that correlates tactics, techniques, and procedures deployed to carry out by each APT. This work proposes an APT detection system (HOLMES) that extracts suspicious information during cyber attacks. HOLMES starts with host logs or audit data, such as Linux auditd or Windows ETW data, and by leveraging the ATT&CK matrix, it issues a detection alert mapping the phases of an ongoing APT campaign. Then, it generates a **high-level scenario graph (HSG)** that represents the attacker's malicious actions in real-time. HSG is employed by security analysts for designing real-time cyber-response operations. The authors have evaluated HOLMES on a dataset provided by DARPA Transparent Computing program that employed a professional red-team simulating nine real-world APT threats on a dynamic network consisting of different platforms. Based on the obtained results, they believe that HOLMES is able to detect and analyze APT campaigns with an acceptable accuracy and low false alarm rate. Finally, HOLMES can be deployed to serve as a real-time intrusion detection tool.

4.1.11 Security Assessment Based on Attack Graphs Using National Vulnerability Database and MITRE ATT&CK Database for Heterogeneous Infrastructures, 2024 [72]. Authors after analyzing modern **Security Information and Event Management (SIEMs)** and identifying the gap that they do not provide accurate mapping of the identified incidents to attacks' stages, present a method to evaluate and assess the security aspects of heterogeneous information systems. The proposed approach involves collecting data from multiple sources, preprocessing logs, detecting security incidents, mapping these incidents to nodes on the attack graph that is considered as the main novelty of this approach, conducting security assessments and forecasts, and presenting the results. For this purpose, the proposed approach employs Emerging Threats correlation rules to generate security incidents based on identified events. Additionally, it utilizes Targeted Attack Analyzer (Indicators of Attack) rules, which describe security incidents (signatures) using the Sigma language, to align detected incidents with attack patterns from the MITRE ATT&CK database. Consequently, this approach enables the mapping of detected events to attack graph nodes, facilitating the assessment and prediction of targeted cyber attacks. The attack graph is constructed using MITRE ATT&CK attack patterns and vulnerabilities from the National Vulnerability Database.

4.1.12 Introducing UWF-ZeekData22: A Comprehensive Network Traffic Dataset Based on the MITRE ATT&CK Framework, 2023 [56]. Authors present a publicly available real network dataset, UWF-ZeekData22, that was collected using Zeek⁴ as an open source traffic analyzer, and labeled according to the MITRE ATT&CK framework. This dataset provides ability to identify attack patterns and detect adversary behavior. The **University of West Florida (UWF)** Cyber Range and UWF Hadoop cluster were used for creating this network traffic data repository. This dataset can be considered as a state-of-the-art **Network Intrusion Detection Systems (NIDS)** benchmark dataset to be employed by NIDS research community. It can be used to evaluate such systems against various aspects of adversarial behaviors.

⁴<https://docs.zeek.org/en/master/about.html>

4.1.13 A Machine Learning Framework for Investigating Data Breaches Based on Semantic Analysis of Adversary's Attack Patterns in Threat Intelligence Repositories, 2019 [21]. This work proposes a machine learning-based framework that detects suspicious and malicious activities based on its previously observed attack patterns used as its training dataset. The proposed solution semantically identifies and correlates threats and TTPs provided by popular knowledge bases, e.g., MITRE ATT&CK, with corresponding detection mechanisms to build a semantic network. Such a dynamic semantic network is employed by security experts to detect various attacks by forming probabilistic relationships among threats and TTPs. For training the proposed framework, the authors use a TTP taxonomy dataset, and they use threat artifacts reported in threat reports for its performance evaluation. Finally, the authors have conducted experimental tests based on a financial malware case study. Their results show 92% accuracy rate and significantly low false-positive rate.

4.1.14 Optimal Machine Learning Algorithms for Cyber Threat Detection, 2018 [26]. This work presents multiple examples about leveraging machine learning analytic to enhance cyber security monitoring and analysis. The authors propose machine learning techniques as an ideal choice to design and develop context-aware detection mechanisms helping to reduce false-positive rate. To this aim, they first analyze multiple taxonomies to choose a standard cyber threat knowledge base. They select ATT&CK and CAPEC to design their methodology. Next, they analyze applications of supervised, semi-supervised and unsupervised techniques in threat detection, and they conclude that semi-supervised algorithms, e.g., One-Class SVM, are significantly efficient and cost-effective enabling SOC analysts conduct new detection methods and discovering new IoCs.

4.1.15 Artificial Intelligence Empowered Cyber Threat Detection and Protection for Power Utilities, 2019 [48]. This work analyse how Artificial Intelligence can enhance the performance and efficiency of traditional cyber attacks detection systems. More specifically, the authors investigate how **Machine Learning (ML)** techniques can detect different attack stages of APT. MITRE ATT&CK framework is employed for this purpose. They believe that AI-enabled detection systems can detect anomalies in wider patterns of adversary activities and present more comprehensive and dynamic detection capabilities. IBM Watson⁵ is adopted for cyber analysis tasks and detecting security threats. Finally, authors consider as a main use case the power utilities SCADA systems.

4.1.16 Automating Cyber Threat Hunting Using NLP, Automated Query Generation, and Genetic Perturbation, 2021 [57]. Authors propose AI-based techniques for the automation of **domain specific language (DSL)** entries in support of threat detection. This work introduces the WILEE system, which is an automated attack hunting system translating high-level abstract cyber threat reports into multiple detailed concepts. Custom DSL is used to represent both high-level and corresponding detailed concepts. WILEE uses such concepts to automatically generate queries to validate the hypotheses tied to the potential adversarial activities. Next, two AI components of WILEE that automate its query generation for hunting are described in detail: (i) a hunt component, called Malmo, that automates extraction and translation of known threat descriptions from MITRE ATT&CK into machine digestible format using NLP techniques and (ii) a genetic programming hunt component, called Genetic Perturbations Engine, as a generator of implementations of threats.

4.1.17 GroupTracer: Automatic Attacker TTP Profile Extraction and Group Cluster in Internet of Things, 2020 [61]. Authors propose a framework, called GroupTracer, for automatically observing and predicting complex **Internet of Things (IoT)** attacks based on ATT&CK matrix. The proposed framework identifies attacks activities by leveraging IoT honeypots and it retrieves

⁵<https://www.ibm.com/watson>

complementary information from corresponding logs. Next, it maps the attack behaviors to the ATT&CK matrix to perform automatic TTP profiles extraction. Finally, using hierarchical clustering techniques and based on four feature groups (TTP profiles, Time, IP, and URL) and 18 characteristics derived from log entries, it clusters attack behaviors and generates attack trees for each cluster to discover potential groups behind complex attacks. In the experiment phase, they compare their proposed algorithm with two baseline algorithms by evaluating 395,006 log entries from 3,025 IPs. Based on the achieved results, they claim that GroupTracer can reach to highly acceptable performance as the Calinski–Harabasz index reaches 3416.93.

4.1.18 DMAPT: Study of Data Mining and Machine Learning Techniques in Advanced Persistent Threat Attribution and Detection, 2021 [64]. This work analyses machine learning and data mining techniques performance and efficiency for APT malware detection and profiling. First, it compares different APT detection techniques and highlights their research gaps to be addressed by cyber security community. The authors believe that even though researchers have proposed different APT detection techniques, there are significant shortcomings to be addressed to enhance current detection mechanisms. The identified challenges are: (i) lack of qualified benchmark datasets for training and evaluation, (ii) continuous changes in TTP usage by APTs resulting high false-positive rate. Consequently, qualified and comprehensive benchmark datasets and well-designed robust machine learning models are needed to characterize and detect APTs.

4.1.19 Open Source Intelligence for Malicious Behavior Discovery and Interpretation, 2021 [45]. Authors propose a MITRE ATT&CK -based **malicious behavior analysis system (MAMBA)** incorporating ATT&CK knowledge into neural network models for MS Windows malware detection. This work exploits **Open Source Intelligence (OSINT)** for the analysis of several malware. The goal is to discover malicious activities and corresponding TTPs by analyzing the execution trace associated with the malware under the Windows operating system. For this purpose, they follow three main phases: (i) OSINT for cyber threat intelligence, (ii) malicious behavior discovery, and, finally, (iii) malicious behavior explanation. Next, they propose the MAMBA system addressing the aforementioned aspects. MAMBA uses a well-designed neural network model to extract TTPs from the ATT&CK matrix and correlate them with corresponding malware API execution call sequences. For regular synchronization with ATT&CK updates, MAMBA automatically collects knowledge in an incremental process. Consequently, they authors believe that MAMBA is explainable, comprehensive and extendable with a significantly high detection rate compared to the other analyzed methods and approaches. To prove this, MAMBA has been evaluated based on four scenarios: (i) performance evaluation and comparison with other methods, (ii) ablation test, (iii) APT29 case study, and, finally, (iv) resource and API locating.

4.1.20 Game-theoretic Decision Support for Cyber Forensic Investigations, 2021 [50]. This work models the interaction between a cyber security analyst and an advanced attacker using a game-theoretic framework (Bayesian game). A graph of actions representing the investigator and the attacker moving across different hosts is generated. The graph edges represent TTPs among different network nodes and the graph nodes represent parties' decisions. Hence, using this modeling the investigator can identify the optimal policies by inspecting the cost and impact of every action. Accordingly, a game-theoretic decision support framework is proposed trying to improve the performance of an investigator against a highly capable attacker. The authors believe that this is the first step toward using game-theoretic concepts for forensic investigations. As for the evaluation, they conduct a series of experiments by constructing a real-life case study based on (i) threat reports collected from the MITRE ATT&CK STIX repository, (ii) Common Vulnerability Scoring System, and, finally, (iii) consultations with cyber security experts. They compare the achieved

results with two other investigative methods (Uniform and CSS) and three different types of attackers.

4.1.21 Fingerprint for Mobile-Sensor APT Detection Framework Based on TTP and MITRE, 2022 [63]. This work proposes a **fingerprint for mobile-sensor APT detection framework (FORMAP)** based on the correlation between the MITRE framework, the mobile sensors and the attack trees. The goal of the proposed framework, namely FORMAP, is to improve the security awareness to detect APT attacks on smartphones. The main objectives of this work are as follows: (i) studying smartphone sensors (inertial, positioning and ambient) vulnerabilities exposed to APT attacks, (ii) designing a set of attacks trees for Mobile APT based on MITRE ATT&CK framework, and, finally, (iii) proposing a smartphone APT detection framework. The authors believe that FORMAP can be a ground knowledge for researchers to better understand mobile phones TTPs.

4.1.22 Evolution of IoT Linux Malware: A MITRE ATT&CK TTP-based Approach, 2021 [59]. Regarding the significant increase on the attacks targeting IoT devices, this research proposes an approach to keep track of the evolution path of techniques and capabilities employed by IoT linux malware. For this purpose, they leverage MITRE ATT&CK matrix to discover and characterize current threats (also covering pre- and post-exploitation aspects) and provide useful insights. In their analysis environment, they analyze 14 unique IoT Linux malware families collected recently. Based on the achieved results, they claim that ransomware are more static respect to botnet malware, which indeed changes quickly and can be employed by different kinds of adversary techniques.

4.1.23 Identifying ATT&CK Tactics in Android Malware Control Flow Graph through Graph Representation Learning and Interpretability, 2021 [49]. This research proposes an approach to automate identifying and locating TTPs in a **Control Flow Graph (CFG)** by using Graph Machine Learning techniques on Android Malware. The authors believe that identifying sub-graphs in the malware CFG provides insights about malware behavior and corresponding mitigation strategies. For this purpose, from a CFG, the sub-graph representing malware executable execution flow is selected (using attribution techniques) and associated with corresponding TTPs. They use Graph Neural Networks and SIR-GN node representation learning technique to analyze CFGs and generate a model that classifies associated TTPs. Based on their experiments, they believe that the proposed methodology outperforms graph isomorphic networks and graph attention networks.

Wrap up on Behavioral analytic. This class of use cases focuses on providing the most accurate model of the adversary in terms of sequence of malicious actions that can be done against a target. The ATT&CK matrix can be very helpful in mainly two ways: (i) as a source of information [12, 17, 26, 31, 49, 50, 56, 59, 69] and (ii) as a support to behavioral modeling [21, 30, 38, 45, 48, 52, 57, 61, 63, 64, 72]. The former considers the ATT&CK matrix as a database of techniques—as indeed it is—while considering hidden relations and extracting correlations to perform a better adversarial modeling to improve the identification of the APT behind the attack. The latter considers the ATT&CK matrix as a support tool for different purposes, e.g., matching the adversarial behavior extracted from real measurements, abstracting from a pattern of actions in a specific scenario to a more general behavior, generalization of results, or finally, driving the analysis of real data. Finally, we found one only paper [23] performing a comparison between the ATT&CK framework and STRIDE, and we decided to report it as standalone.

4.2 Red Teaming

Red teaming represents the set of practices of challenging a target system to test its security and privacy robustness. In this section, we consider the red teaming use case and we study how the current state of the art leverages the ATT&CK framework to enhance such activity.

4.2.1 Threat Modeling Based on the MITRE Enterprise ATT&CK Matrix, 2022 [16]. Authors uses the MITRE Enterprise ATT&CK Matrix to Propose a Threat Modeling Language, Called *enterpriseLang*, for enterprise security. The proposed threat modeling language, which is a DSL, is designed based on the **Meta Attack Language (MAL)** framework [76] and concentrates on representing system assets, asset associations, attack phases, and defense strategies. The attack phases in *enterpriseLang* represent MITRE ATT&CK matrix adversary techniques. For modeling enterprise IT systems, an entity-relationship model is embedded in the language enabling attack simulations on the system model instances. From design perspective, *enterpriseLang* has six steps as follows: (i) problem definition & Motivation, (ii) Defining general and specific Objectives, (iii) Design & Development, (iv) Demonstration, (v) Evaluation, and (vi) Communication. For evaluation, the proposed language is tested based on a group of unit and integration tests. More specifically, *enterpriseLang* is used to model two known real-world attack scenarios: the Ukraine cyber attack and the Cayman National Bank cyber heist.

4.2.2 SoK: A Survey of Open Source Threat Emulators, 2022 [39]. Authors provides a survey reviewing and comparing 11 open source threat emulators to verify whether MITRE ATT&CK tactics and techniques can be performed and tested by these emulators. In this survey, the authors propose a methodology to quantitatively and qualitatively compare threat emulators with respect to a list of criteria and present a taxonomy that illustrates threat emulators quality. The main objective of this work is providing guidelines for security teams to choose the most appropriate cyber threat emulator depending on the target context and application. The investigated threat emulators are as follows: PowerSploit, APTSimulator, Uber's Metta, CALDERA, Infection Monkey, DumpsterFire, Atomic Red Team, Metasploit, Red Team Automation, BT3, and Invoke-Adversary. Their obtained results demonstrate that these four open source threat emulators are outperforming others: RTA, Atomic Red Team, Metasploit, and CALDERA.

4.2.3 Probabilistic Attack Sequence Generation and Execution Based on MITRE ATT&CK for ICS Datasets, 2021 [32]. Authors propose an automatic attack sequence generation approach consistent with MITRE ATT&CK tactics and techniques to define and deploy an attack dataset. In this research, the authors consider three aspects for a qualified attack sequence generation: (i) reproducibility, (ii) diversity, and (iii) reality. Accordingly, they propose an attack sequence generation approach that uses **Hidden Markov Models (HMM)** as its core component. The main characteristics of this approach are as follows: (i) representable attack sequence, (ii) probabilistic attack sequence, and, finally, (iii) practical attack sequence. The authors have evaluated their proposed approach based on three different case studies covering general and specific ICS infrastructures.

4.2.4 powerLang: A Probabilistic Attack Simulation Language for the Power Domain, 2020 [43]. Authors propose *powerLang* as a MAL-based DSL that can model both power domain IT and OT infrastructures. *powerLang* enables power domain practitioners to model their IT/OT architectures and accordingly simulate the activities of malicious entities. This helps them to detect possible security breaches and improve their infrastructure's security. Authors reuse two exiting MAL-based DSL: (i) *coreLang* [77], for modeling common information technology infrastructures, and (ii) *sclLang*,⁶ for modeling the internal schema of substations. Next, to cover the inconsistencies between the information technology infrastructures and other technical infrastructures, they introduce *icsLang* that serves as a tool for modeling OT environments. In their experiment, they evaluate the proposed language against a known cyber security attack, simulating the Ukrainian electric power grid attack scenario.

⁶<https://github.com/mal-lang/SCL-Lang>

4.2.5 Attack Specification Language: Domain-specific Language for Dynamic Training in Cyber Range, 2021 [62]. This research leverages the MITRE ATT&CK framework to propose an **Attack Specific Language (ASL)** that provides a unified representation for all the cyber threat scenarios. ASL provides information and knowledge about attack techniques in a brief format that streamlines and automates the malicious activities of threat and challenge execution. It facilitates designing superior and dynamic threat scenarios by providing comprehensive specification methods. Its main features are of easy implementation, seamless integration and process improvement. Authors use the game-theory modeling to provide a formal proof for an improved ASL dynamic training and customization.

4.2.6 Analysis Of Automated Adversary Emulation Techniques, 2017 [29]. This research propose a test-bed for simulating attackers behavior and activities in Windows-based enterprise networks. After conducting a series of experiments, authors prove that an automated attacker outperforms non-automated ones. Their main objective is expanding the automation to the tactical level despite the existing difficulties and challenges. The major components of the proposed simulation environment are as follows: objects or entities, entity-relationships, and control settings. Each simulation can be considered as a game having three distinct players: an agent simulating user activities, an attacker, and a defender. Overall, 16 scenarios were created including variations of agent actions, vulnerabilities, connections and detection frequencies. They achieved promising initial results in their experiments automating the entire emulation process.

4.2.7 A Review of Threat Modelling Approaches for APT-style Attacks, 2021 [19]. This work proposes a literature review investigating existing threat modeling approaches (49 current studies) and building a threat modeling knowledge base. The main objectives of this research is to define and discover threat modeling challenges, strengths, potential gaps and corresponding enhancements aiming to improve threat modeling efficiency when modeling more complicated attacks, such as the ones coming from APTs. The reviewed research works and approaches are related to different levels of an organization but mainly related to system and data-centric software design, development and operations. Authors claim that there is no particular threat modeling solution covering various assets, threats, vulnerabilities, systems and data. There are a number of features helping to determine which approach to be taken: (i) identify agents, their motivations, and capabilities; (ii) correlate threat intelligence information from multiple sources; (iii) identify critical assets and controls; (iv) include stakeholders from different levels; (v) determine system-wide environmental boundaries; (vi) define authentication and authorization policies; and, finally, (vii) select a comprehensive approach that satisfies pre-defined requirements and consists with the underlying audience and environment.

4.2.8 Toward Dynamic Threat Modelling in 5G Core Networks Based on MITRE ATT&CK, 2021, [58]. Authors propose an approach to extend MITRE ATT&CK framework by adding a list of 5G-related cyber-threat techniques. This research investigates the knowledge sharing between early 5G networks threat analysis and adversarial TTPs of MITRE ATT&CK framework, and it proposes solutions to bridge these gaps. It analyzes the knowledge and theoretical shortcomings of current 5G technology enablers (e.g., Software-defined networking and network functions virtualization). The main objectives are as follows: (i) identifying **5G Core Networks (5GCN)** threat modeling and risk assessment and (ii) adding 5GCN-related adversarial techniques into the MITRE ATT&CK framework. Identifying 5GCN adversarial techniques and mapping them to the MITRE ATT&CK framework tactical stages can empower this framework to serve future 5GCN cyber threat and cyber risk analysis tasks.

4.2.9 From TTP to IoC: Advanced Persistent Graphs for Threat Hunting, 2021 [37]. A formal method modeling cyber security concepts from both attacker and defender point of view is proposed in Reference [37]. For this purpose, two persistent graphs are generated: (i) the execution of attacker's procedures mapped to the MITRE ATT&CK framework and (ii) the exposed resources during the execution of attacker's procedures. The graphs help to reduce false-positive alarm rates for defenders. Additionally, the proposed approach enhances the defender's knowledge base by adding new IoCs enabling proactive threat detection. The authors believe that the mutual inference for both attacker and defender to improve their knowledge is necessary to reach their goals (in particular for the defender). The proposed approach has been evaluated using an attack campaign mimicking APT29 scenario.

Wrap up on Red teaming. The red teaming use case comprises all the papers that leverage the ATT&CK framework to develop, deploy or implement red teaming activities, i.e., malicious activities aiming at testing the security and privacy robustness of a target infrastructure. We identified 3 sub-categories, i.e., *real attacks*, *emulated attacks*, and, finally, *threat (scenario) modeling*. Real attacks [32] involve papers dealing with real attack patterns while considering the ATT&CK matrix to design the attack itself. Emulated attacks [29, 39, 43] involve the study, design and development of tools for the delivery of emulated attacks while the ATT&CK framework is generally considered as the source for the best-known tactics and techniques for performing the attack. Finally, threat modeling [16, 19, 58, 62] involves the development of languages or frameworks for the in-depth description and analysis of the threats.

4.3 CTI Enrichment

The ATT&CK matrix is a database of techniques previously adopted by APTs to launch attacks. When such techniques become linked together to create an attack chain and they can be correlated with other ones to identify and characterize APTs, they become a core component of the CTI—the ATT&CK framework can be considered as a ground-truth for sharing information among organizations, thus enriching the internal intelligence about the current threat landscape.

4.3.1 Assessing MITRE ATT&CK Risk Using a Cyber-Security Culture Framework, 2021 [18]. Authors propose to correlate a well-defined set of features including both organizational and individual features with the MITRE ATT&CK framework TTPs and vulnerability databases. In this work, a multidisciplinary security culture framework covering attack patterns of the MITRE ATT&CK matrix, designed for critical infrastructures is being evaluated. This framework can be applied to a wide range of applications, such as organizing security protocols and improving security evaluation results, and so on. The main objective of the authors is to link a holistic set of cyber security culture factors with the tactics and threats listed in MITRE ATT&CK. The proposed cyber security culture framework evaluates organizations security culture from different perspectives including human- and business-related parameters. For evaluation, they analyze the framework based on two application scenarios (simple and complex) to demonstrate its adaptability with various type of organizations having different sizes and structures.

4.3.2 Cyber Threat Dictionary Using MITRE ATT&CK Matrix and NIST Cybersecurity Framework Mapping, 2020 [20]. Authors propose an attack-defense mapped framework, called **Cyber Threat Dictionary (CTD)**, linking MITRE ATT&CK matrix to NIST Cybersecurity Framework (NIST CSF). Authors believe that CTD can be used re-actively or proactively within critical infrastructures to: (i) identify security gaps to link them to ATT&CK techniques, (ii) develop suitable mitigation and detection techniques, (iii) correlate critical cyber-attack techniques and

the **Facility Cybersecurity Framework (FCF)**⁷ controls, (iv) vulnerability prioritization based on the FCF and the correlation matrix, and (v) develop appropriate prevention solutions. The two major components of CTD are its search engine, which provides details and solution to deal with an attack, and its solution suggestion component, which issues appropriate solutions.

4.3.3 Automated Retrieval of ATT&CK Tactics and Techniques for Cyber Threat Reports, 2020 [22]. This research proposes an automated cyber threat report analysis tool, called rcATT to extract valuable security information from **Cyber Threat Reports (CTRs)**. In this research work, to automate information extraction from CTRs, the authors investigate multi-label text classification techniques and map them to the MITRE ATT&CK tactics and techniques. Accordingly, they present rcATT, a solution for predicting ATT&CK tactics and techniques from input CTRs and providing the results in STIX format. rcATT provides the possibility for users to interactively adjust or correct the classification results and improve its performance over time. For evaluation, they test and compare rcATT's features with available open source solutions and explain its acceptable performance and efficiency.

4.3.4 Learning APT Chains from Cyber Threat Intelligence, 2019, [42]. Authors propose a NLP-based approach to characterize an APT attack actions temporal relationship, and map them to MITRE ATT&CK and STIX-2 frameworks. This research work presents its preliminary results of capturing temporal relationship between threat IoCs provided by cyber threat intelligence. For this purpose, first, they design a set of Regular Expressions (regex) to extract IoCs from text data. Next, they develop an NLP typed dependency rule-set to list the temporal relationship between the IoCs in cyber threat reports and map them to the five stages of kill chain (Deliver, Exploit, Command&Control, Stage, Exfiltrate) associated with the threat IoCs. In the experimentation phase, they process 5000 threat reports from Symantec and Mandiant CTI blogs⁸ and analyze them to generate STIX machine-readable constructs. These constructs can be processed by firewalls and **Intrusion Detection Systems (IDS)**. According to the results, they believe that the IoCs extracted from their dataset represent high temporal order correlation helping security solutions to detect attackers activities based on a sequence of temporal events and corresponding IoCs. This helps to improve detection accuracy by reducing the false-positive alarm rate generated by IDSs.

4.3.5 Linking CVE's to MITRE ATT&CK Techniques, 2021 [28]. This research proposes a neural-network-based model to automate mapping CVE's to ATT&CK techniques. The authors to address the lack of labeled data, propose an unsupervised labeling approach that extracts and analyzes phrases from security reports and ATT&CK technique descriptions. Accordingly, they were able to map 17 techniques and create a knowledge base including 150 attack scenarios and 50 mitigation procedures. The knowledge base includes both adversary and defender views for any input CVE. Next, using the proposed Multi Label Text Classifier, they correlate CVE's with ATT&CK techniques. For evaluation, they use a dataset covering past 10 years CVEs and compare the proposed approach performance with models, such as **Term Frequency-Inverse Document Frequency-(TF-IDF)** based SVM multi-label classifier, **Bi-direction Long Short-Term Memory (BI-LSTM)** and Attention-based BI-LSTM.

4.3.6 Expansion of ICS Testbed for Security Validation Based on MITRE ATT&CK Techniques, 2020 [44]. Authors propose an extended testbed to collect and monitor events during an ICS attack, and map them to the MITRE ATT&CK matrix. In this research, the authors main objective is to collect and monitor information during an ICS attack and map them to MITRE ATT&CK framework.

⁷<https://facilitycyber.labworks.org/>

⁸<https://www.mandiant.com/cyber-threat-intelligence-visualization>

Moreover, they propose a framework to simulate various sophisticated cyber security attack scenarios. For this purpose, they extend an existing testbed called **Hardware-In-the-Loop- (HIL) based Augmented ICS (HAI)**. The authors mainly emphasize on data diversity, data ingestion, attack scenario and time synchronization.

4.3.7 Linking Common Vulnerabilities and Exposures to the MITRE ATT&CK Framework: A Self-Distillation Approach, 2021 [34]. Authors propose a self-distillation model called **CVE Transformer (CVET)** aiming to label CVEs based on information coming from the MITRE ATT&CK framework. CVET includes a fine-tuned distillation model that is the result of using a pre-trained language model called RoBERTa. The proposed methodology has three main components: (i) data collection & pre-processing, (ii) the CVET Architecture, and (iii) benchmark experiments. The proposed model has been evaluated based on a gold-standard dataset and its performance has been compared with classical machine learning (e.g., Random Forest and SVM), deep learning (e.g., RNN and Transformer) and pre-trained NLP models, such as BERT and RoBERTa. As future direction, the authors intend to connect and correlate their framework with the CAPEC list and the NIST framework.

4.3.8 Cyber Threat Intelligence Model: An Evaluation of Taxonomies, Sharing Standards, and Ontologies within Cyber Threat Intelligence, 2017 [13]. This work proposes a CTI model enabling security analysts to analyze cyber-threats. In this research, first the authors discuss about a significant need for an ontology for CTI, and list existing difficulties toward proposing such an ontology, such as lack of standard data representation, comprehensive terminology list and their layered hierarchical relationships. Next, they analyze and evaluates existing taxonomies, standards and ontologies. Finally, they propose a CTI model that tries to improve expressiveness of existing taxonomies and ontologies. For evaluation, they use three criteria: (i) covered data and concepts, (ii) correlation with other taxonomies and ontologies, and (iii) how easily can be analyzed and investigated. Their results show that proposed ontologies must follow Ontology Web Language constraints and restrictions that guarantee high reasoning abilities.

4.3.9 TTPDrill: Automatic and Accurate Extraction of Threat Actions from Unstructured Text of CTI Sources, 2017 [15]. Authors propose an automated and context-aware CTI analytic approach to extract adversarial patterns (TTPs) from accessible CTI repositories and issue appropriate responses. Authors utilizes CAPEC and ATT&CK knowledge bases to propose a comprehensive attack-response ontology to be used for analyzing cyber threats and corresponding responses. In addition, they develop a novel NLP-based approach to search and capture structures TTPs. Finally, they connect these components to build a complete threat actions analysis tool, called TTPDrill, mapping each action to an appropriate TTP. TTPDrill is able to analyze structured and unstructured CTI reports and extract malicious activities and corresponding TTPs in a standard format, such as STIX 2.1. For evaluation, they use a dataset of 17,000 cyber threats reports provided by Symantec. The evaluation results demonstrate that TTPDrill's detection precision and recall goes over 82%.

4.3.10 Integrating Cyber-D&D into Adversary Modeling for Active Cyber Defense, 2016 [27]. This research introduces **cyber Denial and Deception (cyber-D&D)** that uses an experimental and engineering paradigm to combines security research and experiments into cyber-D&D actions. In other words, it discusses how to integrate cyber-D&D tools and TTPs into threat modeling knowledge bases, such as MITRE ATT&CK, aiming to provide active cyber defense recommendations for critical environments and infrastructures. For this purpose, they describe the key elements required for this integration: (i) cyber threat intelligence, (ii) systems and network sensors, (iii) intrusion detection and analysis, (iv) defender mitigation, and (v) Red-Blue experimentation. They

believe that a defensive cyber-D&D integrates standards, threat repositories, operational resources and active defense systems.

4.3.11 Towards a Definition of Cyberspace Tactics, Techniques and Procedures, 2017 [33]. This paper proposes a set of models for offensive cyberspace operations allowing autonomous detection of cyber-attacks. Authors provide the definitions for cyberspace operations supported by mathematical modeling to improve their efficiency and usefulness for advanced data analytics applications. Finally, these definitions are proved to be consistent to model a sequence of real-world cyberspace activities conducted by APT28.⁹

4.3.12 On the use of Cyber Threat Intelligence in Support of Developing the Commander's Understanding of the Adversary, 2019 [40]. This research describes the NATO Allied Command Transformation and the **NATO Communication and Information Agency (NCI Agency)** experiments that concentrate on using deception techniques, such as honeypots to capture and analyze attackers activities data. In particular, the MITRE ATT&CK framework has been utilized during the experiments to identify known adversary patterns and to be correlated with the collected traffic to provide required information for responsible Commanders. The overall goal was achieved by conducting three test cases: (i) validating the importance of honey pots data, (ii) validating the relevancy of captured data with MITRE ATT&CK framework, and, finally, (iii) validating the operational context based on the results of previous steps.

4.3.13 Attack Hypothesis Generation, 2019, [35]. Authors propose an **Attack Hypothesis Generator (AHG)** to generate hypothesis regarding cyber attacks existing in the underlying context. AHG leverages threat intelligence knowledge bases (e.g., MITRE ATT&CK) to issue useful complementary information about the equipment and strategies used by attackers during a cyber-attack. For this purpose, it complements threat intelligence graph by adding information coming from recommendation provision techniques to identify ongoing attacks features and attributes resulting in actionable investigative items. More specifically, authors use machine learning techniques (both supervised and unsupervised) for prediction and collaboration tasks. In summary, AHG's contributions are as follows: (i) utilizing CTIs to enhance attack hypotheses, (ii) enhancing hypotheses accuracy, and (iii) suggesting actionable items. One of the major outcomes and benefits of AHG is improving automated forensic analysis tasks and procedures. For AHG performance evaluation, the authors prepared a hypothesis simulation environment to analyze and compare experts' hypothesis with AHG ones. The results demonstrate significant accuracy increase on the experts' hypothesis that can lead toward high-end and sophisticated investigations and inspections.

4.3.14 Automatically Attributing Mobile Threat Actors by Vectorized ATT&CK Matrix and Paired Indicator, 2021 [36]. Authors propose an automated methodology to classify mobile malware using MITRE ATT&CK framework. For this purpose, a mathematical modeling of the ATT&CK matrix is proposed to analyze and compare IoC and provide complementary insights. The main objective is to automate the task of classifying mobile threat-related TTPs while decreasing the false-positive rate. This can lead to process a significantly high volume of Mobile incidents TTPs that is very useful for the field. In their experiments, they use the proposed approach to evaluate 12 threat actors and 12 malware. Based on their results, the authors believe that this approach can appropriately handle large-volume cyber threat analysis tasks that represents its potentials to be used in various threat intelligence organizations.

⁹<https://attack.mitre.org/groups/G0007/>

4.3.15 Data-Driven Decision Support for Optimizing Cyber Forensic Investigations, 2021 [25]. This paper introduces DISCLOSE: a decision support platform for performing advanced forensic analysis tasks. It uses popular knowledge base, such as MITRE ATT&CK TTPs, as threat intelligence information to characterize threats and their behaviors/activities. Consequently, DISCLOSE empowers the security analysts to conduct efficient investigation of probabilistic relations among attacks actions. For evaluation, the authors verify DISCLOSE performance based on a case study that includes nine cyber threat scenarios (three incidents and corresponding triggering actions) mapped to 31 TTPs.

4.3.16 Price TAG: Toward Semi-Automatically Discovery Tactics, Techniques, and Procedures of E-Commerce Cyber Threat Intelligence, 2021 [65]. The main objective of this research is semi-automatically extracting TTPs from e-commerce threat intelligence corpora and mapping them with MITRE ATT&CK framework. One main challenge is how to efficiently analyze and investigate a significantly high volume of e-commerce data to extract hidden CTIs. For this purpose, authors leverage NLP techniques (e.g., topic modeling and named entity recognition) to propose an approach called **TTP Semi-Automatic Generator (TAG)** performing e-commerce TTP extraction. In their experiments for TAG evaluation, they evaluate TAG using a dataset of 229,729 e-commerce security incidents. Their results show that TAG was able to extract 6,042 TTPs with 80% precision proving that TAG has the capability to analyze highly complex and evolving threats. Moreover, they found a number of emerging 0-day attack patterns and corresponding CTIs showing exploited tools and strategies by attackers. They reported these findings to the Alibaba Group. As future work, they intend to address a limitation that is attackers can evade TAG by adjusting the operational model, such as using utility-preserving adversarial text.

4.3.17 TIM: Threat Context-Enhanced TTP Intelligence Mining on Unstructured Threat Data, 2022 [41]. This research defines TTP intelligence representing all the TTP-related information extracted from the under-analysis dataset. Hence, TTP classification can be represented as a phrase classification task. For TTP intelligence mining, first, they label a dataset of 10,761 cyber threat reports that includes 6 TTP classes and 6,061 TTPs. Next, they propose a **TTP Intelligence Mining (TIM)** framework to extract TTP intelligence insights from a large-volume unstructured security dataset. TIM framework employs Threat Context Enhanced Networks to extract and classify TTP intelligence, and based on the authors claim, it is the first work performing the sentence level TTP classification. its results are generated in STIX 2.1 standard format to be shared and used with other tools. Their evaluation results show 0.941 accuracy that outperforms previous TTP classification approaches. Authors claim that adding TTP element features can even improve this classification accuracy.

4.3.18 Threat Intelligence ATT&CK Extraction Based on the Attention Transformer Hierarchical Recurrent Neural Network, 2022 [55]. This work introduces **Attention-based Transformer Hierarchical Recurrent Neural Network (ATHRNN)** being an NLP attention-based model to automate extracting and analyzing TTPs from unstructured CTI reports. ATHRNN uses MITRE ATT&CK framework as its knowledge base to extract TTPs. Authors present a Transformer Embedding Architecture to retrieve semantic representations of CTIs and corresponding ATT&CK metadata. Next, they present an Attention Recurrent Structure to represent the tactical and technical labels dependencies in MITRE ATT&CK framework. Last, they use a joint Hierarchical Classification model to extract their target tactical and technical categories from cyber threat datasets. To validate their proposed approach, authors build a benchmark dataset from threat reports generated from multiple sources. Their experiments results based on the gathered dataset, represent that they achieved 6.5% and 8.2% accuracy increase for Macro-F score and Micro-F score.

4.3.19 Enhancing the STIX Representation of MITRE ATT&CK for Group Filtering and Technique Prioritization, 2022 [70]. This research enhances the MITRE ATT&CK STIX representation to make it queryable based on various contextual information, such as activity groups motivations, the origin country, the target segments and locations, and so on. For this purpose, authors discuss about the structure of ATT&CK groups and details of the structures (e.g., MITRE's STIX 2.1 representation). Next, they integrate the proposed enhancements to STIX 2.1 format of the MITRE ATT&CK. The enhancements mainly concentrate on the contextual information to enable constructing sophisticated queries and utilize the knowledge base in a more detailed fashion. Hence, they employ STIX 2.1 objects to extract and represent the contextual information in a highly structured format. Finally, they demonstrate how to use the enhanced representation using programming (JSON compatible) and querying languages (e.g., MS SQL).

4.3.20 Visualizing Interesting Patterns in Cyber Threat Intelligence Using Machine Learning Techniques, 2022 [68]. This research proposes a machine learning-based CTI reports visualization mechanism to illustrate hidden insights of threats and help analysts issue appropriate mitigation actions and recommendations. The main goal of the authors is to facilitate understanding the current cyber threat landscape and applying suitable mitigation. For this purpose, they conduct experimental data verification tasks using a set of open source datasets (e.g., Hail-a-Taxii¹⁰). They train machine learning models using ATT&CK TTPs and use them to identify and detect malware behind cyber incidents from multiple perspectives (e.g., domain addresses, IP addresses, prevalent TTPs, file types, etc.). Based on the achieved results, the authors believe that the trained models are able to predict threat actors and malicious activities with 86% accuracy.

4.3.21 Exploiting TTP Co-Occurrence via GloVe-based Embedding with MITRE ATT&CK Framework, 2023 [71]. This research proposes a GloVe-based embedding for MITRE ATT&CK TTPs to be analyzed by deep learning techniques. The proposed embedding method that uses a co-occurrence matrix, is a replacement for simple statistical methods, such as one-hot encoding and TF-IDF that do not take into account the order and conceptual similarity of TTPs. For performance evaluation of the proposed embedding method, they propose a metric called Tactic Match Rate that assesses the semantic similarity of TTP information. Experimental results indicated a correlation value as high as 0.96 between the co-occurrence matrix and the embedding performance for each tactic. However, they believe that context-aware embedding methods like BERT can outperform static methods like GloVe. As their next step, they intend to employ transfer learning with large language models to improve the embedding performance.

4.3.22 Automatic Mapping of Vulnerability Information to Adversary Techniques, 2020 [53]. This research proposes a solution to automate correlating software vulnerabilities to the MITRE ATT&CK framework using multi-label machine learning classification techniques. For this purpose, they use the vector representation of the vulnerability description (e.g., CVE) as an input to a group of multi-label classification methods. The authors believe that using multi-label classification can improve the process of inferring adversarial techniques, because a particular vulnerability can be linked to multiple cyber-threat strategies. For training and evaluation of the classifiers, they use 8,077 examples from a dataset provided by The European Union Agency for Cybersecurity. Their results show that the LabelPowerset and Multilayer Perceptron methods performs better than others.

Wrap up on CTI enrichment. Cyber Threat Intelligence enrichment is a complex process involving several best-practices, methodologies and models to enrich the current state of the CTI.

¹⁰<http://hailataxii.com/>

The general idea is rooted on combining information from different sources to generate a more detailed picture of the threat landscape. The literature review has identified several sources that combined with the ATT&CK framework can enrich the corporate CTI. These sources are: Human factors [18], NIST [20], Reports [22, 42, 65, 68], CVE [28, 34], Logs [40, 44], Text [15, 41, 55], and finally, Tools [27]. A set of papers [25, 35, 36, 70] just considers the ATT&CK matrix as unique source, while References [13, 33] and Reference [71] propose new modeling frameworks to support the CTI enrichment.

4.4 Defensive Gap Assessment

Defensive Gap Assessment is a critical component of the security risk assessment process. Investigating the gaps of the defensive strategies deployed in a corporate ICT infrastructure is of paramount importance—this including the analysis of the tools, procedures and policies to detect and mitigate cyber attacks. The ATT&CK framework can support the defensive gap assessment given the huge amount of techniques and procedures it contains: Assuming a specific business, we can identify the APTs targeting it, and, finally, all the possible tactics, techniques and procedures creating a consistent threat landscape thus enabling the assessment of the current defensive status of the organization.

4.4.1 Security Assessment Rating Framework for Enterprises using MITRE ATT&CK Matrix, 2021 [54]. This work introduces a MITRE ATT&CK -based cyber security analytical rating framework enabling organizations to validate their organizational security aspects. The main idea of this research is to create a risk assessment framework that (i) collects various MITRE ATT&CK techniques, (ii) assign them severity scores based on their impact on the underlying context and the complexity posed to an attacker, (iii) provide their success/failure states from the collected reports and tests. The outcome will be an organization's overall risk assessment rating and the respective coverage of the MITRE ATT&CK matrix per assessment. They believe that this framework helps to reduce the gap between the security operations team and the organization's strategic development team. The proposed framework has been tested with an example enterprise pen-testing assessment.

4.4.2 Cyberattack Models for Ship Equipment Based on the MITRE ATT&CK Framework, 2022 [47]. This work introduces a MITRE ATT&CK -based cyber security analysis approach specifically for ship equipment. Authors investigate and analyze potential cyber security threats on ships using MITRE ATT&CK framework, and present a cyber attack analysis model. For this purpose, they analyze recent ship cyber security research projects and provide essential defense recommendations. Using the proposed model, they list ship navigation, communication and control characteristics; outline main threats and vulnerabilities; and provide mitigation strategies. They evaluated the proposed cyber attack analysis model using four case studies: case (i), a ship sinking; cases (ii) and (iii), wrong routes; and case (iv), an attack on the ship control system. They believe that the obtained results can lead them to conduct their next future work.

4.4.3 MITRE ATT&CK based Evaluation on In-Network Deception Technology for Modernized Electrical Substation Systems, 2022 [66]. Authors introduce a design, implementation and deployment of an in-network deception technology for IEC 61850 standard compliant smart substation systems in smart grid called DecIED. Authors main objective is analyzing various deployment strategies of DecIED to integrate it into a production environment. Moreover, they verify DecIED's performance and efficiency against recently emerged high-profile attacks targeting smart grids. Accordingly, they investigate the procedure of using DecIED for mitigating ICS-related attacks. Their evaluation is accomplished based on the MITRE ATT&CK Matrix for industrial control systems

that provides corresponding tactics and techniques. They evaluate DecIED's effectiveness against well-known real-world cyber attacks, such as Stuxnet¹¹ and Ukraine incidents [78], and show its performance and efficiency in such contexts.

4.4.4 Services for Zero Trust Architectures—A Research Roadmap, 2021, [51]. Authors use information about existing cyber risks as a knowledge base to propose a **Zero Trust Architecture (ZTA)** design methodology. ZTA introduces an interesting paradigm for enhancing cyber security by supporting well-designed, comprehensive and continues security functions in all organizational levels. ZTA's initial assumption is that no organizational entity is trusted. This paper discusses the key pillars of a ZT model and determines deployment challenges both in research and practice. The authors describe the following pillars for ZT model: (i) collecting and analyzing external and internal threats information, (ii) fundamental security patterns, (iii) ZT security patterns, (iv) identifying and choosing services, technology and process improvements, (v) security service implementation, (vi) security control testing, and (vii) performance metrics to measure the effectiveness of the implemented solution. Next, they elaborated on those pillars and challenges and provided potential solutions. Accordingly, they employ MITRE ATT&CK framework to design security patterns.

4.4.5 Application of Advanced Persistent Threat Actors' Techniques for Evaluating Defensive Countermeasures, 2020 [60]. This research describes the results of integrating the MITRE ATT&CK knowledge base TTPs into the process of defining cyber security requirements for information security systems. For this purpose, they follow three major phases: (i) preparation stage that defines systems structural and functional features, (ii) threat modeling stage that is the process of identifying potential origins of information security cyber threats and determining tactics and techniques of the attacker's behavior regarding the structural and functional features, and (iii) security controls selection that is the process of selecting protective security metrics.

4.4.6 A Model and Method of Information System Security Risk Assessment based on MITRE ATT&CK, 2021 [67]. This research presents Advantageous Tactics, Technologies, and Common Knowledge–Optimized Analytic Hierarchy Process–Bayesian Network (ATT&CK-OAHP-BN) that is a risk assessment approach based on MITRE ATT&CK framework. In other words, authors use the MITRE ATT&CK framework to design and develop a hierarchical risk assessment indicators system. Next, using OAHP algorithm, a weight is assigned to each indicator and its initial risk value is calculated. Finally, they use the Bayesian network inference model to calculate each risk indicator probability to happen and discover the most important risks. Based on their experiments on the use case data of the industrial control CPS, they believe that the proposed model can effectively assign appropriate risk values to security threats, and identify the most important risks to be carefully monitored when security threats happen.

Wrap-up on Defensive Gap Assessment. Just a minor amount of papers focuses on this use case although the importance of the ATT&CK matrix is well recognized in the assessing of the defensive gaps for the ICT infrastructure. Out the five identified papers, we highlight that three of them [47, 51, 67] propose new models for gap assessment, one studies the deployment of a rating framework for the security assessment [54], while the last one takes into account an in-network deception infrastructure and the related assessment for its deployment [66].

5 Summary and Key Findings

This section discusses the major findings of our analysis from different perspectives, such as the application scenario, input data, adopted techniques, and finally, datasets.

¹¹<https://www.trellix.com/en-sg/security-awareness/ransomware/what-is-stuxnet.html>

Table 5. Application Scenarios

Application Scenarios		
Operational Technology	Power Grid	[43, 48, 66]
	Maritime	[47]
	Healthcare	[31]
	ICS	[38, 44]
	IoT	[59, 61]
	Water System	[52]
Defense	NATO NCI	[40]
Commercial	Finance	[16]
	E-Commerce	[65]
Telecommunication	5G	[58]
	Cellphone	[63]
Cyber security	Malware Detection	[49]

5.1 Application Scenario

MITRE ATT&CK has been designed and developed based on real attack scenarios. It continuously evolves based on current and emerging attack scenarios seen in real-world applications. In this section, we focus on the analysis of the *application scenarios* as depicted in Table 5. First, out of the considered 56 papers, 16 papers have targeted a particular context/environment/infrastructure to apply their proposed approaches. We identify five main categories: (i) Operational Technology, (ii) Defense, (iii) Commercial, (iv) Telecommunication, and (v) Cyber security. Each category has its own sub-categories as listed in Table 5.

Our analysis shows that industrial/utilities applications, such as ICS, power grids, IoT, and so on, have attracted most of the research works. We believe that the main reason behind this is rooted in the recent advancements of industrial control systems and the integration with complex ICT infrastructures; indeed, attackers can now perform malicious activities to manipulate the controls of power grids, energy providers, and other critical infrastructure. These activities result in real-world catastrophic physical damage, such as major service outage and various service disruptions. To identify vulnerabilities in industrial systems, security-relevant parts must be understood, potential attacks need to be identified, and all weaknesses that can be exploited should be detected. MITRE ATT&CK framework is the major knowledge base for these tasks and accomplishments. Correlating this knowledge base with other information sources that we will mention in the next sections, is a valuable asset.

Last, we observe that many of the proposed solutions target emerging technologies, e.g., 5G, new generation smartphones, and so on, as their *application scenarios* highlighting the importance of MITRE ATT&CK framework for future applications. For example, the recent advances in 5GCN lead to a service-rich technology ecosystem attracting attackers' attention. Hence, numerous 5G network security assessments have been conducted by academics, security groups, and industry suppliers. As another example, social networks attacks, e.g., phishing, is one of the prevalent entry-point toward the compromization of smartphones. Consequently, using continuously updated versions of cyber security knowledge bases like MITRE ATT&CK framework is critical to resist against emerging attacks.

5.2 Input Data

In this section, we provide a categorization of the (input) data taken into account by the papers considered in this work. The considered data is adopted for different purposes such as designing,

Table 6. Input Data

Input	Papers	Conjunction with MITRE ATT&CK
MITRE CVE	[28, 34, 50, 53]	Linking and Mapping
MITRE CAPEC	[15, 26, 53]	Correlating
NIST CSF	[20]	Linking and Mapping
Logs/Audits	[12, 14, 36, 44–46, 52, 61]	Linking and Mapping
Security Reports	[15, 18, 21, 22, 24, 27, 30, 42], [28, 35, 36, 38, 41, 54, 57, 65], [31, 47, 50, 55, 58, 59, 63, 70], [68]	Correlating

developing and validating the adopted methodologies. Table 6 summarizes the input data used in the considered papers. While the MITRE ATT&CK framework constitutes a common knowledge for all the considered papers to design, develop, extend, enhance or validate their proposed solutions, other data sources are as follows: (i) MITRE CVE, (ii) MITRE CAPEC, (iii) NIST Cybersecurity Framework (NIST CSF), (iv) event logs/audits, and (v) security reports.

MITRE CVE, MITRE CAPEC, and NIST CSF are mainly used as datasets to be correlated with the MITRE ATT&CK framework. As previously discussed, MITRE CVE reports the vulnerabilities discovered in a wide range of software and hardware, thus linking it with the MITRE ATT&CK framework generates an improved ground knowledge of tactics, techniques and associated vulnerabilities. MITRE CAPEC focuses on the application security and enumerates exploits against vulnerable systems. It is mainly used for application threat modeling and developer training and education. Hence, it can extend MITRE ATT&CK knowledge base with these information. NIST CSF provides a wide range of defense mechanisms in different domains: identification, protection, detection and recovering. Adding it to the MITRE ATT&CK framework results a more enhanced knowledge base.

Event logs and audit data, e.g., *Linux auditd* and *Windows ETW data*, along with security reports have been used as major sources to automatically discover APTs. The goal is mapping activities found in logs and alerts found in security monitoring systems to the APT kill chain. This provides deep visibility into the attacker TTPs and facilitate threat investigation. However, there are still challenges questioning their usefulness in practice, e.g., validation and investigation, long-term log storage, automated information extraction and analysis, and so on. Machine learning and NLP techniques have been widely used to address these challenges and improve the usage of these information sources in real environments and applications.

There are challenges about using different data sources. The most common challenges are as follows: (i) the temporal or continuous analysis of the proposed approaches based on their used data sources is one of the main challenges researchers may encounter in this field and (ii) the limited volume and comprehensiveness of training data to fine-tune machine learning-based approaches and evaluate the corresponding models.

5.3 Adopted Techniques

Each considered paper employs or integrates different techniques to build and design their methodologies while having MITRE ATT&CK as their main building block. Table 7 lists the adopted techniques and tools for the considered papers. Techniques, such as information correlation, ontology engineering, NLP, machine learning, DSL design and simulating test-beds, have been considered. In addition, some papers integrate security tools (e.g., IDS, Security Information and SIEM) to their proposed methodologies. The main objective of using information correlation

Table 7. Adopted Techniques

Adopted Technique	Papers
Information Correlation	[12, 13, 15, 18, 20, 22, 23, 25–27, 30, 34–38, 40, 42, 44, 60, 61], [45, 45, 46, 46, 47, 49, 49–51, 58, 59, 63, 65–67, 67, 69, 69, 70]
Ontology	[13, 15, 42]
NLP	[15, 22, 41, 42, 55, 57, 65]
ML	[17, 21, 22, 25, 26, 28, 32, 35, 45, 46, 48, 49, 52, 55, 57, 61, 67–69]
DSL	[14, 16, 33, 43, 57]
Simulation test-bed	[29]
IDS/SIEM	[52]

and ontology engineering is to enhance/improve/extend the existing knowledge base, MITRE ATT&CK in particular. Table 6 shows the list of inputs to these techniques in our list of papers. NLP and Machine learning techniques help to automate the knowledge extraction process and split data into well-defined and more accurate classes/clusters for more detailed analysis (e.g., identifying TTPs based on low-level threat artifacts observed in the underlying environment). Among all the adopted techniques, machine learning is the most diversified domain including a large list of models/sub-techniques, such as hierarchical clustering, decision trees, SVM, neural networks, HMM, and so on. Some papers use more than one model to compare their accuracy (experimental analysis) or for complementary purposes. However, machine learning-based analysis should be performed through an optimal workflow to ensure well prepared training/testing datasets and fine-tuned models (predictor, classifier, etc.) for subsequent analysis. This help to address the high volume of false positives and filtering out irrelevant results.

5.4 Datasets

Table 8 shows the list of publicly available datasets referenced by the considered paper in this work. These datasets can be useful to extend/enhance existing approaches toward their future objectives. We also have provided a summary description that represent the type dataset.

Some of these datasets have been prepared specifically for Industrial Control Systems cyber-threat evaluation (e.g., SWaT dataset). Some others provide raw texts as threat and vulnerability reports to be analyzed by NLP techniques. Overall, we believe that this list can be significantly useful for future work in the area as summarized in the next section.

6 Open Issues and Research Directions

In this section, we describe current research challenges and possible future directions that are listed and explained after analyzing the reviewed papers (Table 1 and 2). The proposed research directions are based on use cases, and each addresses the specific challenge(s) of the broad cyber security field considering that the MITRE ATT&CK framework and knowledge base indexes adversary tactics and techniques based on real-world observations. We prioritized the challenges and future directions based on their importance on current real-world applications (e.g., AI, ICS, and IoT). Our analysis is based on the previously introduced categorization in Section 4.

6.1 Challenges and Future Directions in Behavioral Analytic

- *Learning techniques associations* [17]: Reliable construction of technique associations provides insight and knowledge to predict 0-day attack techniques. Future research directions in this field may involve (i) preparing a ground truth attack dataset to enhance the quality and completeness of the associations and (ii) investigating AI-based approaches

Table 8. List of Considered Datasets

Paper	Dataset	Description
[68]	Hail-a-Taxii dataset ¹²	Open source CTI repository
[68]	TTP Dataset [21]	Open source dataset adopted to train machine learning models.
[12]	DARPA Transparent Computing ¹³	An expert red-team simulating multiple attacks on a segmented computer network log files and report
[42]	Symantec ¹⁴ and Mandiant CTI blogs ¹⁵	CTI reports and blogs
[38]	A Secure Water Treatment (SWaT) dataset ¹⁶	A labeled dataset of water treatment normal and abnormal network traffic generated by iTrust Cyber Security Research Centre.
[37]	APT29 Activity From the ATT&CK Evaluations ¹⁷	Includes the generated logs by re-running both parts of an attack scenario
[69]	ATT&CK for Industrial Control Systems: Groups ¹⁸	It provides an index of APT groups
[45]	MalShare ¹⁹	Malware database
[34]	BRON knowledge graph dataset [79]	Linking Attack Tactics, Techniques, and Patterns with defensive weaknesses, vulnerabilities and affected environment configurations
[57]	Operationally Transparent Cyber (OpTC) evaluation set ²⁰	Operationally Transparent Cyber (OpTC) was a technology transition pilot study funded under Boston Fusion Corp.'s Cyber APT Scenarios for EnterpriseSystems (CASES) project
[44]	HAI testbed dataset [80]	The hardware-in-the-loop (HIL)-based augmented ICS (HAI) testbed and dataset
[28]	APT reports that are published from 2008 to 2019 ²¹	APT & cybercriminals campaign collection
[28]	Zero-day exploits observed by google project zero ²²	This datasets includes observed exploited zero-days vulnerabilities
[28]	63720 vulnerability reports ²³	Vulnerability reports from Symantec
[28]	37000 threat reports ²⁴	Threat reports from Symantec
[24]	Malpedia [81]	A Collaborative effort to inventorize the malware landscape
[53]	State of vulnerabilities 2018/2019 ²⁵	European Union Agency for Cybersecurity (ENISA), Tech Report, 2019
[56]	UWF-ZeekData22 ²⁶	A Comprehensive Network Traffic Dataset Based on the MITRE ATT&CK Framework

(e.g., hierarchical clustering) to reveal probabilistic technique associations to highlight pre-conditions and post-conditions relationships.

¹²<http://hailataxii.com/>

¹³<https://github.com/darpa-i2o/Transparent-Computing>

¹⁴<https://www.broadcom.com/support/security-center?>

¹⁵<https://www.mandiant.com/advantage/threat-intelligence>

¹⁶https://itrust.sutd.edu.sg/itrust-labs_datasets/dataset_info/

¹⁷<https://github.com/OTRF/detection-hackathon-apt29>

¹⁸<https://attack.mitre.org/groups/>

¹⁹<https://malshare.com/>

²⁰<https://github.com/FiveDirections/OpTC-data>

²¹https://github.com/CyberMonitor/APT_CyberCriminal_Campagin_Collections

²²<https://googleprojectzero.blogspot.com/p/0day.html>

²³<https://www.symantec.com/security-center/vulnerabilities>

²⁴<https://www.symantec.com/security-center/a-z>

²⁵<https://github.com/enisaeu/vuln-report/>

²⁶<https://datasets.uwf.edu/>

- *Characterizing attackers behavior [30]*: Analyzing various datasets, in particular those collected from penetration testing competitions, can provide valuable insights to discover and exploit software systems weaknesses on a typical way. The results can improve security experts knowledge toward the goal of designing and developing secure software systems.
- *Modeling attacks and defenses [23]*: Multiple propositions for security attacks and defense modeling have been proposed, e.g., BACCER [23] in Section 4. Continued refinement of these modeling systems and using them within various use case-targeted demonstrations can be a suitable future direction. Moreover, evaluating the modeling systems based on multiple real scenarios and analyzing the results to apply to broader cyber security applications can be another future direction.
- *Real-time multi-step cyberattack detection [46]*: APT attacks are often categorized as multistage attacks. During such attacks, attackers drop malware on the victim systems and try to distribute and transfer it to the whole organization. Future directions might involve (i) developing more advanced and intelligent techniques for detecting multistage attacks, (ii) early multistage attacks detection that needs gaining knowledge about the most recent adopted techniques by adversaries and the end-to-end procedure of such attacks.
- *Risk assessment [31]*: MITRE ATT&CK -based risk assessment has been studied by researchers in the recent years as it reveals information and knowledge about attackers' interests, motivations, abilities, and so on. Integrating organization-specific information is another missing contribution in the current research, e.g., collecting information from/about honeypots and IoCs, and so on.
- *Similarity analysis [69]*: This technique can be used to capture similarity degrees of adversary behaviors based on various semantic links among APT groups. The results can be used as threat intelligence information for advanced threat analysis. Future directions can be: (i) analyzing the similarity of attackers activities and behavior to learn attackers habits and enrich the ground-truth of attack patterns, (ii) attacks have time-lines, and the time dimension can be added to analyze the attackers' mindset.
- *Data source analysis [14]*: Data source is a critical factor biasing the behavioral analytic. Current challenges on data source analysis are: (i) current approaches considers each endpoint independently and cross-machine provenance has not been fully analyzed yet, (ii) most of the existing implementations and experiments are offline, while real-time analysis has still challenges, such as integrating new data structures and threat scoring algorithms, (iii) adaptive attacks employ tactics in an unpredictable way to bypass detection algorithms. Advanced scoring algorithms are required to address this challenge, (iv) real APT behaviors instead of simulated ones are required to conduct comprehensive analysis and experiments, and (v) some attacks do not trigger alerts, which in turn should be generated by underlying EDR systems.
- *Case Study—Industrial Control Systems [38]*: ICS threat hunting frameworks have been extensively studied and investigated. The first phase of the threat hunting process is the hypothesis proposition that is defining a list of potential threats to be verified and investigated using CTI information. Automating hypothesis verification (quality and reliability) and threat intelligence generation tasks can improve response issuing time. Consequently, the future directions can be (i) improving initial hypothesis reliability and (ii) automating hypothesis verification and threat intelligence generation using machine learning techniques.
- *Case Study—Internet of Things [59]*: researchers have studied the advancement of techniques and strategies utilized by IoT malware by leveraging MITRE ATT&CK matrix to analyze and characterize (e.g., the pre- and post- exploitation aspects of an attack) current IoT-related

cyber attacks. Developing an efficient automated IoT malware investigation along with expanding the research to cover emerging threats can be important research directions.

6.2 Challenges and Future Directions in Red Teaming

- *MITRE ATT&CK role in Adversarial AI [82]*: AI red teams and security groups can employ MITRE ATT&CK knowledge base to design and develop adversary tactics and techniques against AI-enabled systems based on real-world attack observations and realistic demonstrations. Considering the broad usage of AI techniques within various sectors and critical environments, this challenge and research direction needs to be urgently analyzed and investigated to identity-related vulnerabilities and potential threats. MITRE ATLAS [83] has recently opened this research avenue.
- *Threat modeling [16]*: This concept is used to identify the list of existing assets and resources within an environment and corresponding potential threats. Threat modeling is used to validate security status of an existing system or to develop a new system with the security-by-design strategy. An important future direction is to calculate and assign probability scores to cyber attack steps/stages to make the modeling and simulation results more and more realistic.
- *Adversary emulation [29]*: Adversary emulation provides a solid method to verify a system resilience against various advances cyber attacks. However, automating this task still has several technical challenges, such as techniques encoding, and the coordination of their deployment.
- *Advanced persistent graphs for threat hunting [37]*: Such graphs represent the attack patterns of the adversary through the network during the persistent attack campaign. As future directions, we refer to all the techniques involving graph similarity computation to generate metrics to reliably estimate the effectiveness of the attack and the defense.
- *Case study—dynamic threat modeling in 5GCN [58]*: As the APTs continue to expand and cover emerging technologies, a potential target for threat actors is 5GCN. Hence, several security researchers, analysts and industry suppliers have proposed different 5GCN security assessment approaches and solutions. Future research directions can be as follows: (i) generating datasets that include identified 5GCN attack scenarios and conducting advanced security analysis and assessments, (ii) analytical study to prepare a comprehensive list of requirements for 5GCN adversarial techniques detection and mitigation, (iii) proposing an appropriate risk assessment approach to cover emerging 5GCN TTPs and provide complementary 5GCN risk evaluation recommendations, and (iv) proposing an analytical framework based on game-theory to model adversary and defender's activities within 5GCN infrastructures.

6.3 Challenges and Future Directions in CTI Enrichment

- *Automatic and accurate extraction of CTI data from unstructured texts [15]*: Automated extraction and analysis of CTI information from various unstructured and free-style reports and texts have attracted researchers to propose appropriate solutions. These research directions are still valid: (i) using popular NLP solutions (e.g., Google NLP and Azure Language Studio) to extract and analyze CTIs from cyber security reports and comparing the results accuracy and efficiency, (ii) extending CTI reports repositories to cover various cyberthreat threat source and languages, and (iii) constructing a TTP graph for enhanced extraction, investigation and prediction of emerging TTPs.
- *Learning APT chains from cyber threat intelligence [42]*: Using machine learning techniques to learn temporal relations between malicious artifacts to provide insights for threat analysts of the malicious activities happening on the underlying environment.

- *Attack hypothesis generator [35]*: Leveraging the advantages of CTI knowledge and insights to generate a set of hypotheses for the underlying environment facilitates forensic analysts analytical tasks. Future research directions might consider including features matching with domain expert knowledge, such as target operating system, kill chain steps and information sources, can improve attack hypothesis generator's accuracy.
- *Expanding MITRE ATT&CK framework [34]*: MITRE ATT&CK framework can be extended to include more information sources, such as CVE, CWE, CAPEC, NIST, and so on. In addition, future research direction can be as follows: (i) conducting experiments to compare the expanded framework performance on bench-marking datasets in other fields, (ii) examining the security strength of the extended framework under adversarial settings and threat models, and (iii) investigating more refined textual data representation techniques (e.g., novel word embedding strategies, synonym/homonym generation, POS tagging) to improve the features of input texts.
- *Cyber threat intelligence ontology [13]*: Representing and sharing cyber security analytical data and information in an optimized fashion require a unified format and a set of standard protocols between researchers other entities. A solution proposed by researchers is the use of ontologies. Although various ontologies have been proposed in the literature, a well-designed multi-layered CTI ontology is still an important need to be considered as a research direction.

6.4 Challenges and Future Directions in Defensive Gap Assessment

- *ZTA [51]*: The main objective of a ZTA model is protecting organizations assets, such as data, systems and services, against attackers. Hence, there are a list of challenges to address as future research directions: (i) updating current digital infrastructure to be compatible with ZTA is costly and introduces various technical and knowledge-wide difficulties, (ii) compatibility and integration of ZTA with cloud-based platforms has still unsolved challenges, (iii) integrating ZTA to emerging technologies (e.g., 5G/6G networks) will oppose novel challenges.
- *Case study—cyberattack models for ship equipment [47]*: Upgrading ship technology and integrating high-end IT and communication technologies to this industry introduces novel security challenges. Future research directions might include the following: (i) design and develop risk management approaches compatible with the ship industry, (ii) developing a honeypot system to identify malicious activities, potential attack and help to improve threat detection accuracy by reducing false alarm rate, (iii) leveraging AI benefits and integrating them to ship cyber threat detection and response technology, (iv) using maritime CTI information for analyzing, classification and verification of maritime cyber threat analysis, and (v) integrating the digital forensic technology to maritime for analyzing cyber incidents of onboard systems.

7 Conclusion

The MITRE ATT&CK framework serves as a foundation for the development of threat models employed in various sectors including both private and government. Essentially, the MITRE ATT&CK framework constitutes from a set of techniques and sub-techniques representing adversaries' behaviors toward their objectives. In this survey, we introduced a detailed analysis of the MITRE ATT&CK framework while considering the state of the art contributions in the field. We have provided a description of the MITRE ATT&CK framework while comparing it with other threat intelligence frameworks such as STRIDE and the Cyber kill chain. We classified all the works considered in our analysis by use cases, i.e., behavioral analytic, red teaming, CTI enrichment, and finally, defensive gap assessment. For each class, we listed the extracted insights and its main characteristics in the course of utilizing the MITRE ATT&CK framework. In addition,

as our key findings, we categorized the considered works as per application scenarios (e.g., operational technology, defense, commercial, telecommunication and cyber security), input data (e.g., MITRE CVE, MITRE CAPEC, NIST CSF, event logs/audits and security reports), adopted techniques (e.g., information correlation, ontology engineering, NLP and IDS/SIEM), and datasets (e.g., CTI repositories, malware databases, TTPs and event logs). Finally, we discussed open issues and potential research directions for each particular use case, while drawing some final remarks.

Acknowledgments

This publication was made possible by the awards NPRP12S-0125-190013 and GRSA7-1-0516-20061 from Qatar National Research Fund (a member of Qatar Foundation). The contents herein are solely the responsibility of the author[s].

References

- [1] Rasheed Ahmad, Izzat Alsmadi, Wasim Alhamdani, and Lo'ai Tawalbeh. 2023. Zero-day attack detection: A systematic literature review. *Artif. Intell. Rev.* 56, 10 (2023), 10733–10811.
- [2] Yuri Diogenes and Erdal Ozkaya. 2022. *Cybersecurity—Attack and Defense Strategies: Improve your Security Posture to Mitigate Risks and Prevent Attackers from Infiltrating Your System*. Packt Publishing Ltd.
- [3] Blake E. Strom, Andy Applebaum, Doug P. Miller, Kathryn C. Nickels, Adam G. Pennington, and Cody B. Thomas. 2018. *Mitre Att&ck: Design and Philosophy*. Technical Report. The MITRE Corporation.
- [4] Lockheed Martin's Cyber Kill Chain. Retrieved from <https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html>
- [5] Loren Kohnfelder and Praerit Garg. The Threats to Our Products. Retrieved October 16 2022 from <https://shostack.org/files/microsoft/The-Threats-To-Our-Products.docx>
- [6] Paul Pols and Jan van den Berg. 2017. *The Unified Kill Chain*. CSA Thesis, Hague.
- [7] Sergio Caltagirone, Andrew Pendergast, and Christopher Betz. 2013. *The Diamond Model of Intrusion Analysis*. Technical Report. Center For Cyber Intelligence Analysis and Threat Research Hanover Md.
- [8] Michael Howard and David LeBlanc. 2003. *Writing Secure Code*. Pearson Education.
- [9] Process for Attack Simulation and Threat Analysis (PASTA). Retrieved from <https://versprite.com/blog/what-is-pasta-threat-modeling/>
- [10] NIST SP 800-154. Retrieved from <https://csrc.nist.gov/pubs/sp/800/154/ipd>
- [11] Alessandro Liberati, Douglass G. Altman, Jennifer Tetzlaff, Cynthia Mulrow, P. C. Gøtzsche, J. P. A. Ioannidis et al. 2009. The PRISMA statement for reporting systematic and meta-analyses of studies that evaluate interventions: Explanation and elaboration. *PLoS Med.* 6, 7 (2009), 1–28.
- [12] Sadeq M. Milajerdi, Rigel Gjomemo, Birhanu Eshete, Ramachandran Sekar, and V. N. Venkatakrishnan. 2019. Holmes: Real-time apt detection through correlation of suspicious information flows. In *Proceedings of the IEEE Symposium on Security and Privacy (SP'19)*. IEEE, 1137–1152.
- [13] Vasileios Mavroeidis and Siri Bromander. 2017. Cyber threat intelligence model: An evaluation of taxonomies, sharing standards, and ontologies within cyber threat intelligence. In *Proceedings of the European Intelligence and Security Informatics Conference (EISIC)*. IEEE, 91–98.
- [14] Wajih Ul Hassan, Adam Bates, and Daniel Marino. 2020. Tactical provenance analysis for endpoint detection and response systems. In *Proceedings of the IEEE Symposium on Security and Privacy (SP'20)*. IEEE, 1172–1189.
- [15] Ghaith Husari, Ehab Al-Shaer, Mohiuddin Ahmed, Bill Chu, and Xi Niu. 2017. Ttpdrill: Automatic and accurate extraction of threat actions from unstructured text of cti sources. In *Proceedings of the 33rd Annual Computer Security Applications Conference*. 103–115.
- [16] Wenjun Xiong, Emeline Legrand, Oscar Åberg, and Robert Lagerström. 2022. Cyber security threat modeling based on the MITRE enterprise ATT&CK matrix. *Softw. Syst. Model.* 21, 1 (2022), 157–177.
- [17] Rawan Al-Shaer, Jonathan M Spring, and Eliana Christou. 2020. Learning the associations of mitre att & ck adversarial techniques. In *Proceedings of the IEEE Conference on Communications and Network Security (CNS'20)*. IEEE, 1–9.
- [18] Anna Georgiadou, Spiros Mouzakitis, and Dimitris Askounis. 2021. Assessing mitre att&ck risk using a cyber-security culture framework. *Sensors* 21, 9 (2021), 3267.
- [19] Matt Tatam, Bharanidharan Shanmugam, Sami Azam, and Krishnan Kannoorpatti. 2021. A review of threat modelling approaches for APT-style attacks. *Heliyon* 7, 1 (2021), e05969.
- [20] Roger Kwon, Travis Ashley, Jerry Castleberry, Penny Mckenzie, and Sri Nikhil Gupta Gouriseti. 2020. Cyber threat dictionary using mitre att&ck matrix and nist cybersecurity framework mapping. In *Proceedings of the Resilience Week (RWS'20)*. IEEE, 106–112.

- [21] Umara Noor, Zahid Anwar, Asad Waqar Malik, Sharifullah Khan, and Shahzad Saleem. 2019. A machine learning framework for investigating data breaches based on semantic analysis of adversary's attack patterns in threat intelligence repositories. *Fut. Gener. Comput. Syst.* 95 (2019), 467–487.
- [22] Valentine Legoy, Marco Caselli, Christin Seifert, and Andreas Peter. 2020. Automated retrieval of att&ck tactics and techniques for cyber threat reports. arXiv:2004.14322. Retrieved from <https://arxiv.org/abs/2004.14322>
- [23] Jeremy Straub. 2020. Modeling attack, defense and threat trees and the cyber kill chain, att&ck and stride frameworks as blackboard architecture networks. In *Proceedings of the IEEE International Conference on Smart Cloud (Smart-Cloud'20)*. IEEE, 148–153.
- [24] Kris Oosthoek and Christian Doerr. 2019. Sok: Att&ck techniques and trends in windows malware. In *Security and Privacy in Communication Networks: 15th EAI International Conference, SecureComm 2019, Orlando, FL, USA, October 23-25, 2019, Proceedings, Part I* 15 (2019), 406–425.
- [25] Antonia Nisioti, George Loukas, Aron Laszka, and Emmanouil Panaousis. 2021. Data-driven decision support for optimizing cyber forensic investigations. *IEEE Trans. Inf. Forens. Secur.* 16 (2021), 2397–2412.
- [26] Hafiz M. Farooq and Naif M. Otaibi. 2018. Optimal machine learning algorithms for cyber threat detection. In *Proceedings of the UKSim-AMSS 20th International Conference on Computer Modelling and Simulation (UKSim'18)*. IEEE, 32–37.
- [27] Frank J. Stech, Kristin E. Heckman, and Blake E. Strom. 2016. Integrating cyber-D&D into adversary modeling for active cyber defense. In *Cyber Deception*. Springer, 1–22.
- [28] Aditya Kuppa, Lamine Aouad, and Nhien-An Le-Khac. 2021. Linking CVE's to MITRE ATT&CK techniques. In *Proceedings of the 16th International Conference on Availability, Reliability and Security*. 1–12.
- [29] Andy Applebaum, Doug Miller, Blake Strom, Henry Foster, and Cody Thomas. 2017. Analysis of automated adversary emulation techniques. In *Proceedings of the Summer Simulation Multi-Conference*. 1–12.
- [30] Nuthan Munaiah, Akond Rahman, Justin Pelletier, Laurie Williams, and Andrew Meneely. 2019. Characterizing attacker behavior in a cybersecurity penetration testing competition. In *Proceedings of the ACM/IEEE International Symposium on Empirical Software Engineering and Measurement (ESEM)*. IEEE, 1–6.
- [31] Mohamed Ahmed, Sakshyam Panda, Christos Xenakis, and Emmanouil Panaousis. 2022. MITRE ATT&CK-driven cyber risk assessment. In *Proceedings of the 17th International Conference on Availability, Reliability and Security*. 1–10.
- [32] Seungoh Choi, Jeong-Han Yun, and Byung-Gil Min. 2021. Probabilistic attack sequence generation and execution based on mitre att&ck for ics datasets. In *Cyber Security Experimentation and Test Workshop*. 41–48.
- [33] Fernando Maymí, Robert Bixler, Randolph Jones, and Scott Lathrop. 2017. Towards a definition of cyberspace tactics, techniques and procedures. In *Proceedings of the IEEE International Conference on Big Data (Big Data'17)*. IEEE, 4674–4679.
- [34] Benjamin Ampel, Sagar Samtani, Steven Ullman, and Hsinchun Chen. 2021. Linking common vulnerabilities and exposures to the MITRE ATT&CK framework: A self-distillation approach. arXiv:2108.01696. Retrieved from <https://arxiv.org/abs/2108.01696>
- [35] Aviad Elitzur, Rami Puzis, and Polina Zilberman. 2019. Attack hypothesis generation. In *Proceedings of the European Intelligence and Security Informatics Conference (EISIC'19)*. IEEE, 40–47.
- [36] Kyoungmin Kim, Youngsup Shin, Justin Lee, and Kyungho Lee. 2021. Automatically attributing mobile threat actors by vectorized ATT&CK matrix and paired indicator. *Sensors* 21, 19 (2021), 6522.
- [37] Aimad Berady, Mathieu Jaume, Valérie Viet Triem Tong, and Gilles Guette. 2021. From TTP to IoC: Advanced persistent graphs for threat hunting. *IEEE Trans. Netw. Service Manage.* 18, 2 (2021), 1321–1333.
- [38] Zahra Jadidi and Yi Lu. 2021. A threat hunting framework for industrial control systems. *IEEE Access* 9 (2021), 164118–164130.
- [39] Polina Zilberman, Rami Puzis, Sunders Bruskun, Shai Shwarz, and Yuval Elovici. 2020. Sok: A survey of open-source threat emulators. arXiv:2003.01518. Retrieved from <https://arxiv.org/abs/2003.01518>
- [40] Manisha Parmar and Alberto Domingo. 2019. On the use of cyber threat intelligence (CTI) in support of developing the commander's understanding of the adversary. In *Proceedings of the IEEE Military Communications Conference (MILCOM'19)*. IEEE, 1–6.
- [41] Yizhe You, Jun Jiang, Zhengwei Jiang, Peian Yang, Baoxu Liu, Huamin Feng, Xuren Wang, and Ning Li. 2022. TIM: threat context-enhanced TTP intelligence mining on unstructured threat data. *Cybersecurity* 5, 1 (2022), 1–17.
- [42] Ghaith Husari, Ehab Al-Shaer, Bill Chu, and Ruhani Faiheem Rahman. 2019. Learning APT chains from cyber threat intelligence. In *Proceedings of the 6th Annual Symposium on Hot Topics in the Science of Security*. 1–2.
- [43] Simon Hacks, Sotirios Katsikeas, Engla Ling, Robert Lagerström, and Mathias Ekstedt. 2020. powerLang: A probabilistic attack simulation language for the power domain. *Energy Inf.* 3, 1 (2020), 1–17.
- [44] Seungoh Choi, Jongwon Choi, Jeong-Han Yun, Byung-Gil Min, and HyoungChun Kim. 2020. Expansion of {ICS} testbed for security validation based on {MITRE}{ATT&CK} techniques. In *Proceedings of the 13th USENIX Workshop on Cyber Security Experimentation and Test (CSET'20)*.

- [45] Yi-Ting Huang, Chi Yu Lin, Ying-Ren Guo, Kai-Chieh Lo, Yeali S. Sun, and Meng Chang Chen. 2021. Open source intelligence for malicious behavior discovery and interpretation. *IEEE Trans. Depend. Sec. Comput.* 19, 2 (2021), 776–789.
- [46] Yuvraj Sanjayrao Takey, Sai Gopal Tatikayala, Satyanadha Sarma Samavedam, P. R. Lakshmi Eswari, and Mahesh Uttam Patil. 2021. Real time early multi stage attack detection. In *Proceedings of the 7th International Conference on Advanced Computing and Communication Systems (ICACCS'21)*, Vol. 1. IEEE, 283–290.
- [47] Yonghyun Jo, Oongjae Choi, Jiwoon You, Youngkyun Cha, and Dong Hoon Lee. 2022. Cyberattack models for ship equipment based on the MITRE ATT&CK framework. *Sensors* 22, 5 (2022), 1860.
- [48] Kamrul Hasan, Sachin Shetty, and Sharif Ullah. 2019. Artificial intelligence empowered cyber threat detection and protection for power utilities. In *Proceedings of the IEEE 5th International Conference on Collaboration and Internet Computing (CIC'19)*. IEEE, 354–359.
- [49] Jeffrey Fairbanks, Andres Orbe, Christine Patterson, Janet Layne, Edoardo Serra, and Marion Scheepers. 2021. Identifying ATT&CK tactics in android malware control flow graph through graph representation learning and interpretability. In *Proceedings of the IEEE International Conference on Big Data (Big Data'21)*. IEEE, 5602–5608.
- [50] Antonia Nisioti, George Loukas, Stefan Rass, and Emmanouil Panaousis. 2021. Game-theoretic decision support for cyber forensic investigations. *Sensors* 21, 16 (2021), 5300.
- [51] Elisa Bertino and Kenneth Brancik. 2021. Services for zero trust architectures-a research roadmap. In *Proceedings of the IEEE International Conference on Web Services (ICWS'21)*. IEEE, 14–20.
- [52] Firdevs Seyde Toket, Kevser Ozav Akpinar, and Ibrahim Özçelik. 2021. MITRE ICS attack simulation and detection on EtherCAT based drinking water system. In *Proceedings of the 9th International Symposium on Digital Forensics and Security (ISDFS'21)*. IEEE, 1–6.
- [53] Otgonpurev Mendsaikhan, Hirokazu Hasegawa, Yukiko Yamaguchi, and Hajime Shimada. 2020. Automatic mapping of vulnerability information to adversary techniques. In *Proceedings of the 14th International Conference on Emerging Security Information, Systems and Technologies (SECUREWARE'20)*.
- [54] Hardik Manocha, Akash Srivastava, Chetan Verma, Ratan Gupta, and Bhavya Bansal. 2021. Security assessment rating framework for enterprises using MITRE ATT&CK matrix. arXiv:2108.06559. Retrieved from <https://arxiv.org/abs/2108.06559>
- [55] Chenjing Liu, Junfeng Wang, and Xiangru Chen. 2022. Threat intelligence ATT&CK extraction based on the attention transformer hierarchical recurrent neural network. *Appl. Soft Comput.* 122 (2022), 108826.
- [56] Sikha S. Bagui, Dustin Mink, Subhash C. Bagui, Tirthankar Ghosh, Russel Plenkers, Tom McElroy, Stephan Dulaney, and Sajida Shabanali. 2023. Introducing uwf-zeekdata22: A comprehensive network traffic dataset based on the mitre att&ck framework. *Data* 8, 1 (2023), 18.
- [57] Prakruthi Karuna, Erik Hemberg, Una-May O'Reilly, and Nick Rutar. 2021. Automating cyber threat hunting using NLP, automated query generation, and genetic perturbation. arXiv:2104.11576. Retrieved from <https://arxiv.org/abs/2104.11576>
- [58] Robert Pell, Sotiris Moschogiannis, Emmanouil Panaousis, and Ryan Heartfield. 2021. Towards dynamic threat modelling in 5G core networks based on MITRE ATT&CK. arXiv:2108.11206. Retrieved from <https://arxiv.org/abs/2108.11206>
- [59] Veronica Chierzi and Fernando Mercés. 2021. Evolution of IoT linux malware: A MITRE ATT&CK TTP based approach. In *Proceedings of the APWG Symposium on Electronic Crime Research (eCrime'21)*. IEEE, 1–11.
- [60] Anna P. Golushko and Vadim G. Zhukov. 2020. Application of advanced persistent threat actor techniques for evaluating defensive countermeasures. In *Proceedings of the IEEE Conference of Russian Young Researchers in Electrical and Electronic Engineering (EIConRus'20)*. IEEE, 312–317.
- [61] Y. Wu, C. Huang, X. Zhang, and H. Zhou. 2020. Grouptracer: Automatic attacker TTP profile extraction and group cluster in Internet of things. *Security and Communication Networks* 2020, 1 (2020), 8842539.
- [62] Sobia Arshad, Masoom Alam, Saif Al-Kuwari, and Muhammad Haider Ali Khan. 2021. Attack specification language: Domain specific language for dynamic training in cyber range. In *Proceedings of the IEEE Global Engineering Education Conference (EDUCON'21)*. IEEE, 873–879.
- [63] A. A. Al-Kadhimi, M. M. Singh, and T. Jabar. 2022. Fingerprint for mobile-sensor apt detection framework (FORMAP) based on tactics techniques and procedures (TTP) and Mitre. In *Proceedings of the 8th International Conference on Computational Science and Technology (ICCST'21)*. 515–533.
- [64] P. V. Sai Charan, P. Mohan Anand, and Sandeep K. Shukla. 2021. DMAPT: Study of data mining and machine learning techniques in advanced persistent threat attribution and detection. In *Data Mining-Concepts and Applications*. IntechOpen.
- [65] Yiming Wu, Qianjun Liu, Xiaojing Liao, Shouling Ji, Peng Wang, Xiaofeng Wang, Chunming Wu, and Zhao Li. 2021. Price TAG: Towards semi-automatically discovery tactics, techniques and procedures OF E-commerce cyber threat intelligence. *IEEE Trans. Depend. Sec. Comput.* (2021).

- [66] Daisuke Mashima. 2022. MITRE ATT&CK based evaluation on in-network deception technology for modernized electrical substation systems. *Sustainability* 14, 3 (2022), 1256.
- [67] Tian He and Zhihua Li. 2021. A model and method of information system security risk assessment based on MITRE ATT&CK. In *Proceedings of the 2nd International Conference on Electronics, Communications and Information Technology (CECIT'21)*. IEEE, 81–86.
- [68] Sarwat Ejaz, Umara Noor, and Zahid Rashid. 2022. Visualizing interesting patterns in cyber threat intelligence using machine learning techniques. *Cybernet. Inf. Technol.* 22, 2 (2022), 96–113.
- [69] Wenhao Wang, BenFu Tang, Cheng Zhu, Bin Liu, Aiping Li, and Zhaoyun Ding. 2020. Clustering using a similarity measure approach based on semantic analysis of adversary behaviors. In *Proceedings of the IEEE 5th International Conference on Data Science in Cyberspace (DSC'20)*. IEEE, 1–7.
- [70] Mateusz Zych and Vasileios Mavroeidis. 2022. Enhancing the STIX representation of MITRE ATT&CK for group filtering and technique prioritization. arXiv:2204.11368. Retrieved from <https://arxiv.org/abs/2204.11368>
- [71] Chanhoo Shin, Insup Lee, and Changhee Choi. 2023. Exploiting ttp co-occurrence via glove-based embedding with mitre att&ck framework. *IEEE Access* (2023).
- [72] Roman Kryukov, Elena Vladimirovna Fedorchenko, Igor Kotenko, Evgenia Novikova, and Vladimir Zima. 2024. Security assessment based on attack graphs using NVD and MITRE ATT & CK database for heterogeneous infrastructures. 2 (2024), 39–50.
- [73] Shanto Roy, Emmanouil Panaousis, Cameron Noakes, Aron Laszka, Sakshyam Panda, and George Loukas. 2023. SoK: The MITRE ATT&CK Framework in Research and Practice. arXiv:cs.CR/2304.07411. Retrieved from <https://arxiv.org/abs/2304.07411>
- [74] Barbara Hayes-Roth. 1985. A blackboard architecture for control. *Artif. Intell.* 26, 3 (1985), 251–321.
- [75] Brian W. Kernighan and Shen Lin. 1970. An efficient heuristic procedure for partitioning graphs. *Bell Syst. Techn. J.* 49, 2 (1970), 291–307.
- [76] Pontus Johnson, Robert Lagerström, and Mathias Ekstedt. 2018. A meta language for threat modeling and attack simulations. In *Proceedings of the 13th International Conference on Availability, Reliability and Security*. 1–8.
- [77] Sotirios Katsikeas, Simon Hacks, Pontus Johnson, Mathias Ekstedt, Robert Lagerström, Joar Jacobsson, Max Wallstedt, and Per Eliasson. 2020. An attack simulation language for the it domain. In *International Workshop on Graphical Models for Security*. Springer, 67–86.
- [78] Kim Zetter et al. 2016. Inside the cunning, unprecedented hack of Ukraine’s power grid. *Wired* 9 (2016), 1–5.
- [79] Erik Hemberg, Jonathan Kelly, Michal Shlapentokh-Rothman, Bryn Reinstadler, Katherine Xu, Nick Rutar, and Unamay O’Reilly. 2020. BRON-linking attack tactics, techniques, and patterns with defensive weaknesses, vulnerabilities and affected platform configurations. arXiv:2010.00533. Retrieved from <https://arxiv.org/abs/2010.00533>
- [80] Hyeok-Ki Shin, Woomyo Lee, Jeong-Han Yun, and HyoungChun Kim. 2019. Implementation of programmable {CPS} testbed for anomaly detection. In *Proceedings of the 12th USENIX Workshop on Cyber Security Experimentation and Test (CSET'19)*.
- [81] Daniel Plohmann, Martin Clauss, Steffen Enders, and Elmar Padilla. 2017. Malpedia: A collaborative effort to inventoize the malware landscape. In *Proceedings of the Botnet & Malware Ecosystems Fighting Conference (Botconf'17)*.
- [82] Chuyen Nguyen, Caleb Morgan, and Sudip Mittal. 2022. Poster cti4ai: Threat intelligence generation and sharing after red teaming ai models. In *Proceedings of the ACM SIGSAC Conference on Computer and Communications Security*. 3431–3433.
- [83] MITRE ATLAS: Adversarial Threat Landscape for Artificial-Intelligence Systems. Retrieved from <https://atlas.mitre.org/>

Received 31 January 2023; revised 4 June 2024; accepted 30 July 2024